

Hitachi Solutions Europe

Cloud Assessment

Client Name: CQC

Document Number: 0.1

Submission Date: 9th June 2026

Status: DRAFT

Table of Contents

Introduction.....	5
Executive Summary.....	5
Assessment Vision.....	6
Assessment Objectives.....	6
Assessment Flow	6
Stakeholders	6
Access Granted	7
Health Check Conclusions.....	8
HCAF Maturity Scorecard	8
HCAF Maturity Scorecard - Results	8
Cloud Strategy Analysis.....	10
Organisational Context.....	10
Drivers, Goals (North Star), Blockers, & Risks.....	11
Categories of Blockers and Risks	13
How Might We statements.....	14
Effort Vs Impact	15
Readiness Gaps.....	17
Guard Rails	18
Integrated advisory view.....	20
Cloud Governance.....	22
Current State Overview.....	22
A. Cloud Structure.....	23
B. Cloud Guardrails (Policy & Compliance).....	25
C. Cloud Operating Model & Cloud Onboarding.....	27
D. Data Governance.....	30
Recommendations	31
Networking and Security	33
Current State Overview.....	33
Network Topology	33
Network Security and Traffic Management.....	34
Hybrid Connectivity.....	34
Core Services	35
Recommendations	36
External Exposure	38
Current State Overview.....	38
No Managed DDoS Protection.....	38
Public IP SKU Posture.....	38
Firewall Tier and Inspection Gap.....	38
Recommendations	39

Secret & Key Management 40
Current State Overview.....40
Public Network Access by Default.....40
Legacy Authorisation Model.....40
Resilience and Forensic Controls.....40
Cross-Environment Vault Linkage.....41
Recommendations41

Identity Management..... 42
Current State Overview.....42
Identity Infrastructure.....42
Privileged Access42
Managed Identities and Automation.....43
Defender for Cloud and Sentinel43
Recommendations44

Zero Trust 46
What Zero Trust Means in This Context.....46
Zero Trust Assessment.....46

Platform Operations and Observability 48
Current State Overview.....48
Azure Monitor and Log Analytics48
Alerting.....49
Workload Monitoring49
Security Monitoring.....50
Operational Integration.....50
Recommendations51

Workloads 52
Application Services52
Storage53
Compute53
Recommendations53

Cost and Financial Management (FinOps)..... 56
Current State Overview.....56
Major Cost Contributors56
Optimisation Challenges.....56
Potential Savings57
Recommendations59

Focus Area: AIS (Application Integration Services) 60
Objective.....60
Solution Overview.....60
Observations - AIS.....65
Recommendations68

Appendix: Integration Patterns Example 70

Focus Area: Data and AI Platforms 72

Current State Overview..... 72

Observations - Data Platform..... 73

Observations - Data Governance (Purview)..... 74

Observations - AI and ML Operations..... 75

EDP, Data and AI: Key Risks 76

Recommendations 77

Consolidated Health Check Recommendations 79

Technical Programme Leadership (Individual or group) 80

Roadmap 82

From recommendations to delivery: the work package layer 83

Team and Organisation 84

Phased Delivery..... 85

Cross-Workstream Dependencies..... 88

Glossary of Terms 91

Contacts 93

Introduction

Executive Summary

The assessment has established three things.

First, CQC's cloud strategy is sound. The target direction is clear: a CAF-aligned landing zone, stronger governance, better observability, cost transparency, and a platform that supports data-driven regulation. The CCoE charter, the cloud strategy paper, and the ambitions expressed across every workshop are all pointing in the same direction.

Second, the current estate is not yet capable of delivering on that direction. Governance is split across three management-group hierarchies. Policy enforcement varies by subscription placement. Standing privilege is high. Observability is fragmented. Cost attribution is not possible. The legacy estate absorbs disproportionate effort and masks the risks underneath it. Every technical chapter in this document describes a different facet of the same problem: the organisation is trying to move forward while carrying an estate that is not controlled.

Third, work is already underway. CQC is not starting from zero. The platform team is building the new landing zone. Security is improving identity hygiene. FinOps analysis is identifying waste. AIS, EDP and the Regulatory Platform are all evolving. The issue is not a lack of activity. It is a lack of coordination across that activity. Teams are delivering in parallel, but without a single view of what should come first, what depends on what, and who arbitrates when priorities compete.

The chapters that follow set out the findings and recommendations in detail, domain by domain, and bring them together into a consolidated set of priorities and a sequenced delivery plan. The aim throughout is not to replace the work already underway, but to make it deliberate, sequenced and governed.

Assessment Vision

“To establish a secure, scalable, and data-driven cloud platform that enables CQC to deliver smarter regulation, foster innovation, and uphold public trust.”

CQC's stated approach is “cloud-first, but not cloud-only”, retaining flexibility to integrate SaaS and on-premises systems where they remain fit for purpose. The target outcomes are a fully aligned CAF landing zone, automated deployments via IaC and DevSecOps, self-service through mature processes, Zero Trust across workloads, an established Cloud Centre of Excellence (“CCoE”) with full business buy-in, a resilient platform with tested disaster recovery, and a FinOps practice with cost transparency.

Assessment Objectives

- Build upon CQC's existing strategy paper and previous cloud assessments. This is not a vanilla assessment; it is bespoke to CQC's regulatory mandate and dual-estate reality.
- Address the immediate need for a technical programme owner to “hold the pen” on the digital rebuild.
- Sequence and dependency-map the work in line with the in-flight CCoE charter and cloud strategy.
- Align to the Microsoft Cloud Adoption Framework (“CAF”) and the Well-Architected Framework (“WAF”), and to GovAssure and NCSC Cyber Assessment Framework obligations.
- Focus on Zero Trust Architecture, the AIS workload, and the Data and AI estate.

Assessment Flow

The assessment was delivered through a structured programme of engagement sessions, supplemented by read-only discovery against CQC's Azure tenant and analysis of stakeholder-supplied documentation. The findings in this document are drawn from that combined evidence base.

Stakeholders

External and partner references: DHSC (parent department, cyber strategy alignment), CDIO (accountable owner for scope and ownership decisions), Little Fish (managed-service partner for identity administration and the legacy firewall), KPMG (legacy implementation partner), Avanade (ARA framework and AI HLD/LLD), Node 4 (ARA support contract), Infosys (Siebel CRM operations), NHS CSOC via Azure Lighthouse, Vodafone (public DNS hosting).

Access Granted

Hitachi Solutions was granted Reader access across the platform and decommissioned subscriptions, Owner on legacy workload subscriptions, and Specified Access on the newer landing-zone subscriptions. Stakeholders and SMEs were made available throughout the engagement, and CQC shared the relevant policies, standards and roadmap material.

Health Check Conclusions

HCAF Maturity Scorecard

The scorecard below summarises the current and target maturity state for each HCAF pillar.

The maturity model is a 5-level scale:

Level	Name
1	Initial
2	Developing
3	Defined
4	Managed
5	Optimised

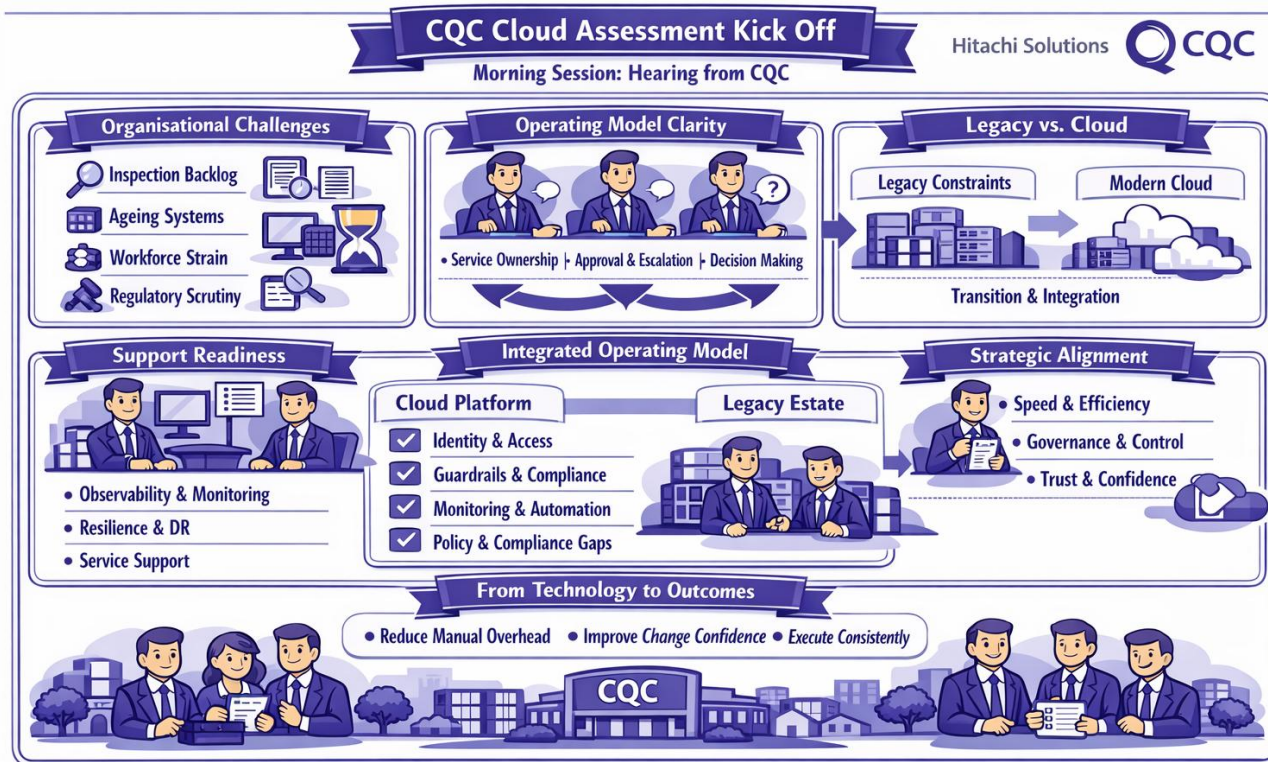
HCAF Maturity Scorecard - Results

Pillar	Current Level	Target Level	Evidence
Cloud Governance	(2) Developing	Managed	Three parallel Management Group hierarchies in flight; 19 subscriptions sitting directly under mg-cqc-legacy; two subscriptions bypassing all Management Group policy
FinOps and Cost Management	(2) Developing	Defined	£2.185M annualised spend with zero CostCenter or BusinessOwner tag coverage; no budgets configured at Management Group level
Management and Monitoring	(1) Initial	Defined	296 monitoring resources but 100% of inspected resources have no diagnostic forwarding; mean Secure Score 59.8% against 75% target
Identity and Access Management	(1) Initial	Defined	1,116 service principals holding 2,955 role assignments; 163 Classic Administrator grants persisting; only 30% of grants via groups

Network Security	(2) Developing	Managed	32% average NSG coverage across VNets; 34 isolated VNets outside the centrally governed hub; hub-and-spoke partially realised
External Exposure	(2) Developing	Managed	Zero DDoS Standard protection across 40 Public IPs; 2 of 7 WAF policies in Detection mode; 5 unsupported Basic SKU Public IPs
Secret and Key Management	(1) Initial	Managed	107 of 118 Key Vaults allow public network access; 86 still on legacy Access Policies; 66 without Purge Protection
Data Services	(2) Developing	Defined	7 SQL Servers running on Virtual Machines; 32 data services with public network access; database-level tag coverage sparse
Compute	(3) Defined	Managed	100% OS disk encryption; 55 legacy SKU VMs awaiting modernisation; 154 of 194 VMs with VMTier = Unknown
Application Services	(1) Initial	Defined	All 12 APIM instances allow public access; 0 of 161 Function Apps enforce authentication; 6 Developer SKU APIM instances in non-trial use
Storage	(2) Developing	Managed	70.4% of accounts allow shared-key authentication; 58% allow public network access; 17.1% allow anonymous blob access
Operations and Backup	(2) Developing	Managed	547 alert rules and 110 action groups deployed but zero ITSM integration; Cross-Region Restore disabled on all 20 RSVs; 41% of backup items not actively protected

Cloud Strategy Analysis

Organisational Context



CQC is under pressure from several directions at once: previous transformation failure, an inspection backlog, ageing systems, delivery friction, workforce strain, and scrutiny of its regulatory effectiveness. The cloud estate sits inside that problem. Where systems are hard to change, hard to monitor, weakly owned or inconsistently governed, they add drag to an organisation that already has little headroom.

The issue is therefore not platform modernisation alone. It is whether CQC can improve the speed, consistency and confidence of regulation while supporting inspectors and operational teams. That depends as much on the operating model as on the technology. Workshops returned repeatedly to the same gaps:

- Service ownership and accountability
- Approval routes and escalation paths

- Support readiness and operational handoffs
- Decision-making authority

Two points shape the rest of this analysis:

- **Transition, not destination.** Newer cloud patterns are emerging, but the legacy estate remains harder to govern, document and support. CQC must improve while carrying a mixed environment, not pause to redesign from scratch. This is a sequencing and control-maturity challenge.
- **Supportability from day one.** Observability, resilience, disaster recovery and service support are foundational, not optional. A platform that works in principle but cannot be supported, monitored and governed in practice will not restore regulatory confidence.

Drivers, Goals (North Star), Blockers, & Risks



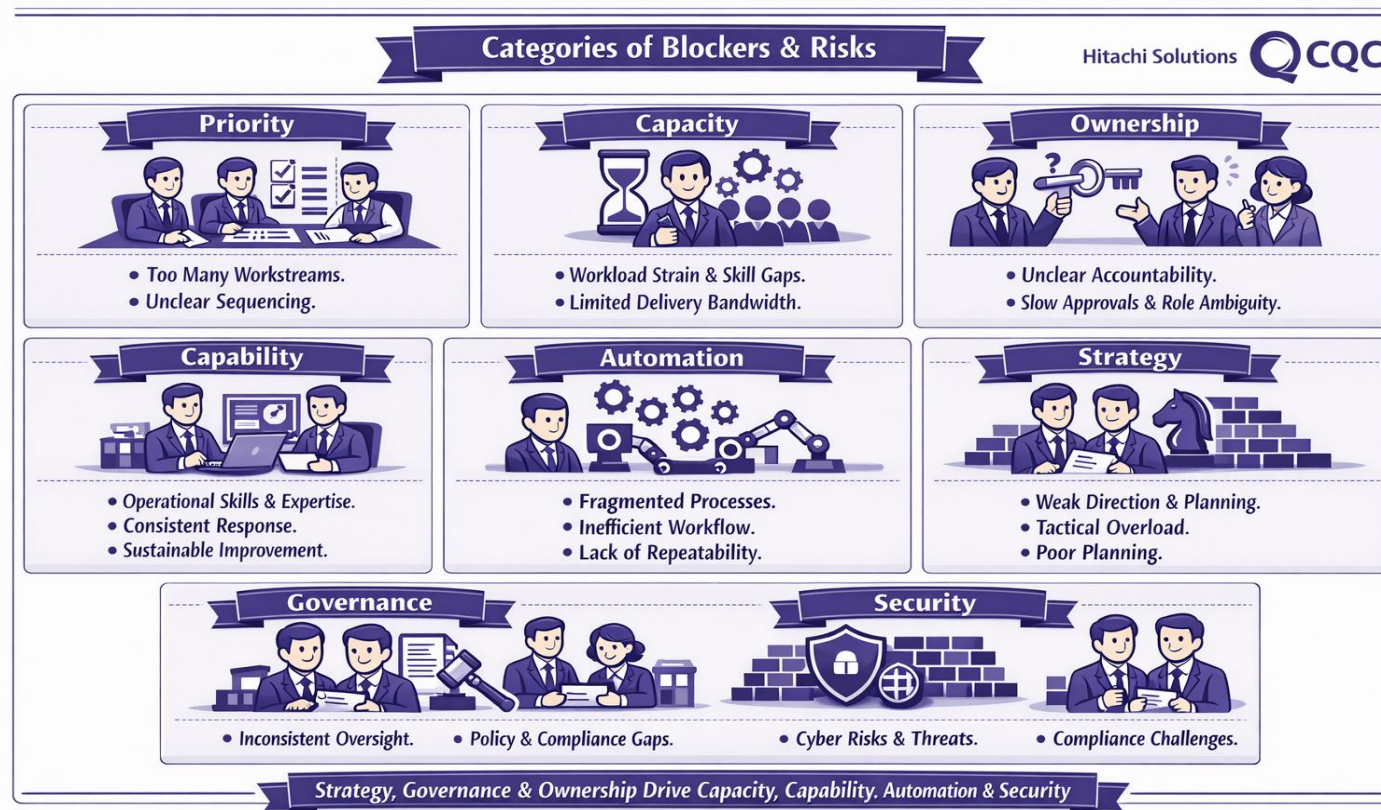
The drivers behind the strategy are strategic, operational and regulatory rather than technical. Cloud is treated as a mechanism for becoming more resilient, more governable and better able to support the regulatory mission, not as an end in itself.

The North Star that emerged is defined by control, consistency and self-sufficiency:

- Clearer landing zones
- Stronger identity governance
- Reusable engineering patterns
- Better observability and supportability
- Less dependence on manual workarounds

The blockers form a connected pattern, not a set of isolated gaps: unclear ownership, inconsistent governance, fragmented monitoring, incomplete integration patterns, weak automation, and uneven maturity between the legacy and new-world environments. Each of CQC's goals, from stronger service delivery to more credible regulation, depends on the same condition: the ability to execute change in a disciplined, governed and supportable way. That execution layer is where the most important work now sits. Trust is not only an external outcome. It is built internally through consistent ownership, stronger observability and repeatable delivery, so the strategy's softer goals of confidence and credibility rest on the harder mechanics of platform discipline.

Categories of Blockers and Risks



The assessment grouped the blockers into eight categories: Priority, Capacity, Ownership, Capability, Automation, Strategy, Governance and Security. Three sit at the top of the causal chain and deserve most leadership attention.

- **Priority.** The dominant category. Too many workstreams compete with too little clarity on what comes first. Fragmentation, not any single gap, is the largest risk.
- **Ownership.** Cuts across almost every objective. Where accountability is unclear, support is inconsistent, change approval slows, and governance depends on individuals.
- **Strategy and Governance.** Treated as design

conditions for the future platform, not downstream checks.

Capacity is broader than headcount. It is shaped by workload, focus, administrative burden and repeatability, so some delivery strain is relieved through stronger patterns and prioritisation rather than recruitment alone. Capability, Automation and Security are enabling conditions rather than separate workstreams: if Priority, Ownership and Governance remain weak, the others are consumed inefficiently. The categorisation also separates direct barriers from their downstream effects, which is a stronger basis for programme design than responding to visible symptoms.

How Might We statements



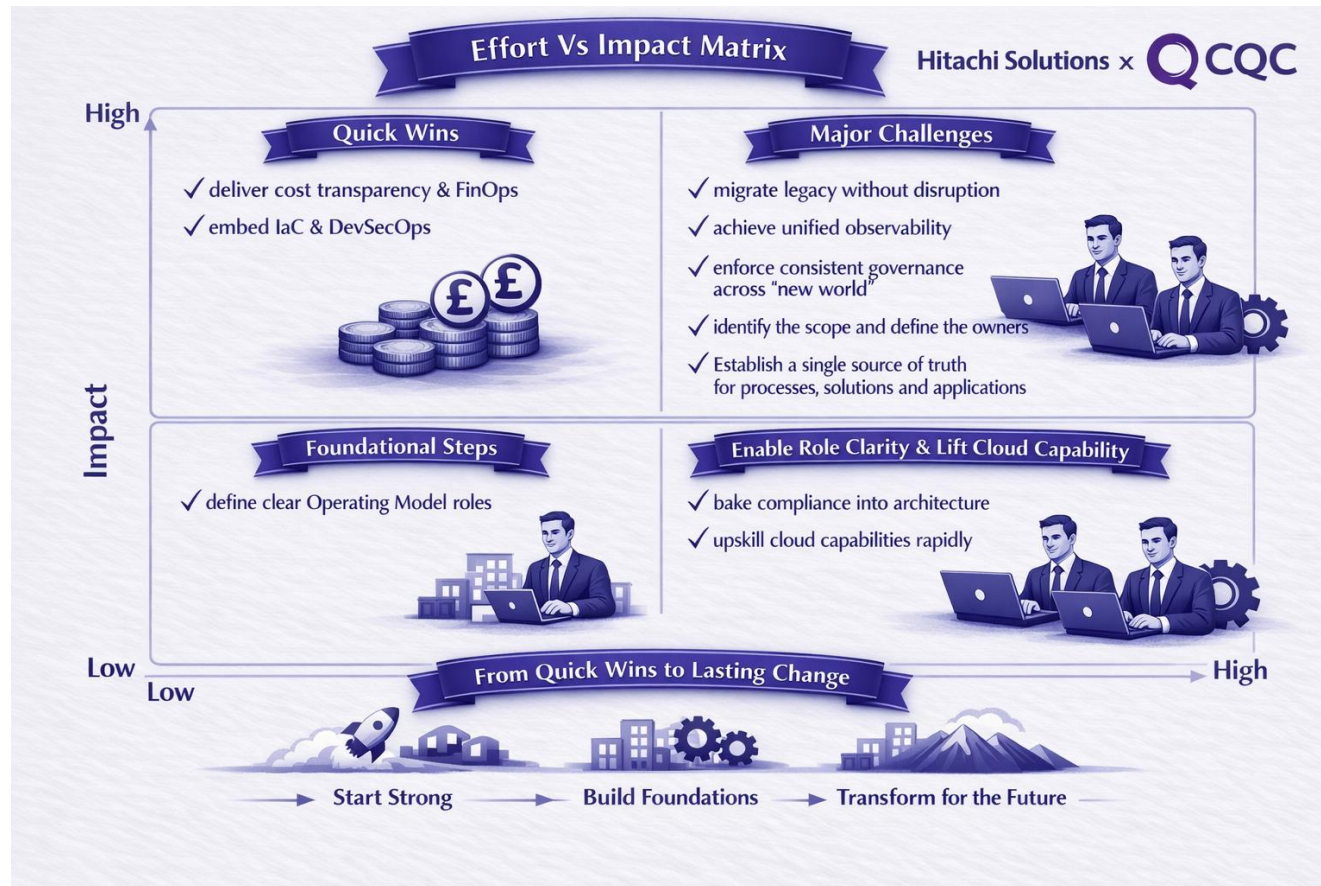
The "How Might We" exercise converted strategic pressure into concrete design questions around operating-model clarity, ownership, governance, observability, cost transparency, capability and legacy transition. They are early design hypotheses, not yet a plan, but they show where progress is needed and who needs to lead it:

- **End-to-end ownership.** A single source of truth for service accountability. An organisational question for the CDIO and the business, not only a technical one.
- **Compliance by design and legacy transition.** Led by the architecture function, which needs design authority rather than a review role.
- **Cost transparency and FinOps.** Owned by the platform function, so spend informs sequencing and investment decisions.

- **Cloud capability uplift.** Practical recruitment, certification and capability-building to sustain the target model.

The questions split cleanly into those needing executive authority (scope, accountability, business influence) and those needing functional ownership (patterns, compliance by design, engineering discipline).

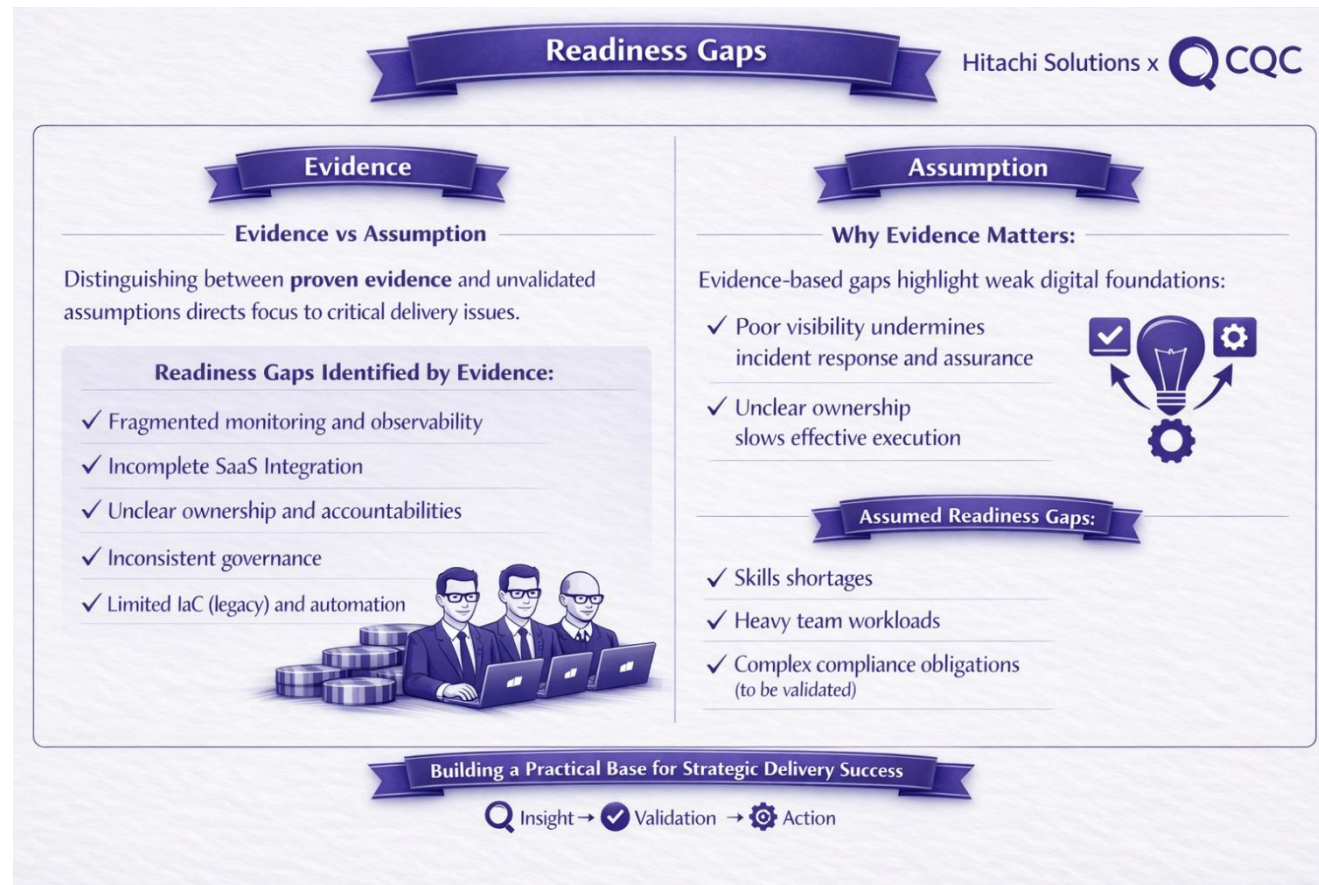
Effort Vs Impact



Most of the design questions sit in the high-impact half of the matrix. The useful distinction is between what creates early momentum and what requires deeper structural change. The matrix points to a three-part path:

- **Near-term enablers.** Cost transparency and FinOps, and embedding IaC and DevSecOps more consistently. These improve visibility and delivery discipline and can create early momentum.
- **Foundational clarity.** Defining operating-model roles. Lower effort and lower impact on its own, but a prerequisite for stronger execution.
- **Structural change.** Migrating legacy without disruption, unified observability, consistent governance enforcement, and capability uplift. Legacy migration is the heaviest and most consequential item, and makes the case for phased delivery.

Readiness Gaps

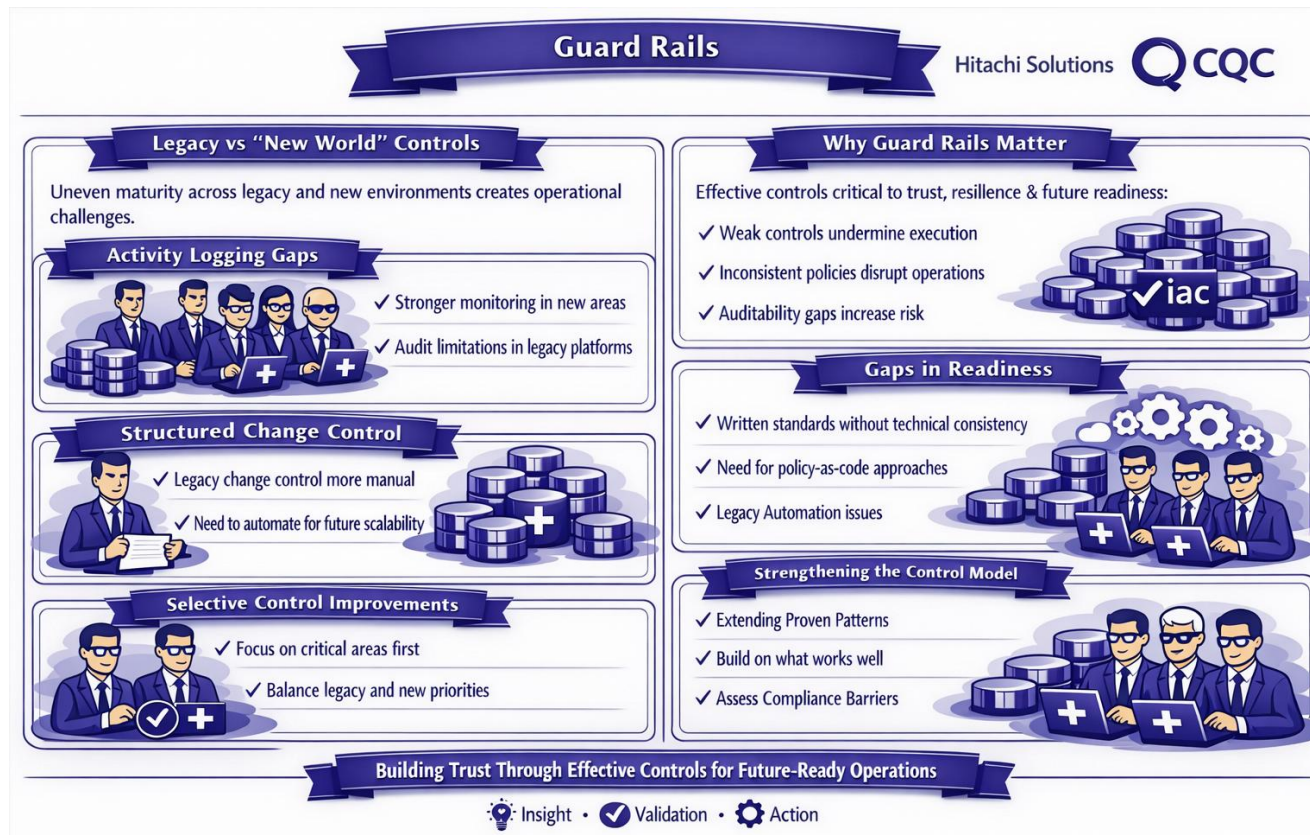


The evidence-versus-assumption exercise separates current, evidenced weakness from themes that still need validation. The evidenced items are concrete and foundational:

- Weak observability, which already affects confidence and underpins incident response, assurance and decision-making
- Incomplete integration patterns
- Unclear ownership and inconsistent governance, both already slowing execution
- Limited automation in the legacy estate

The findings are more measured on skills shortages and compliance complexity. These may be symptoms of workload pressure, prioritisation and weak implementation patterns rather than root causes, and should be validated before major intervention is designed around them.

Guard Rails

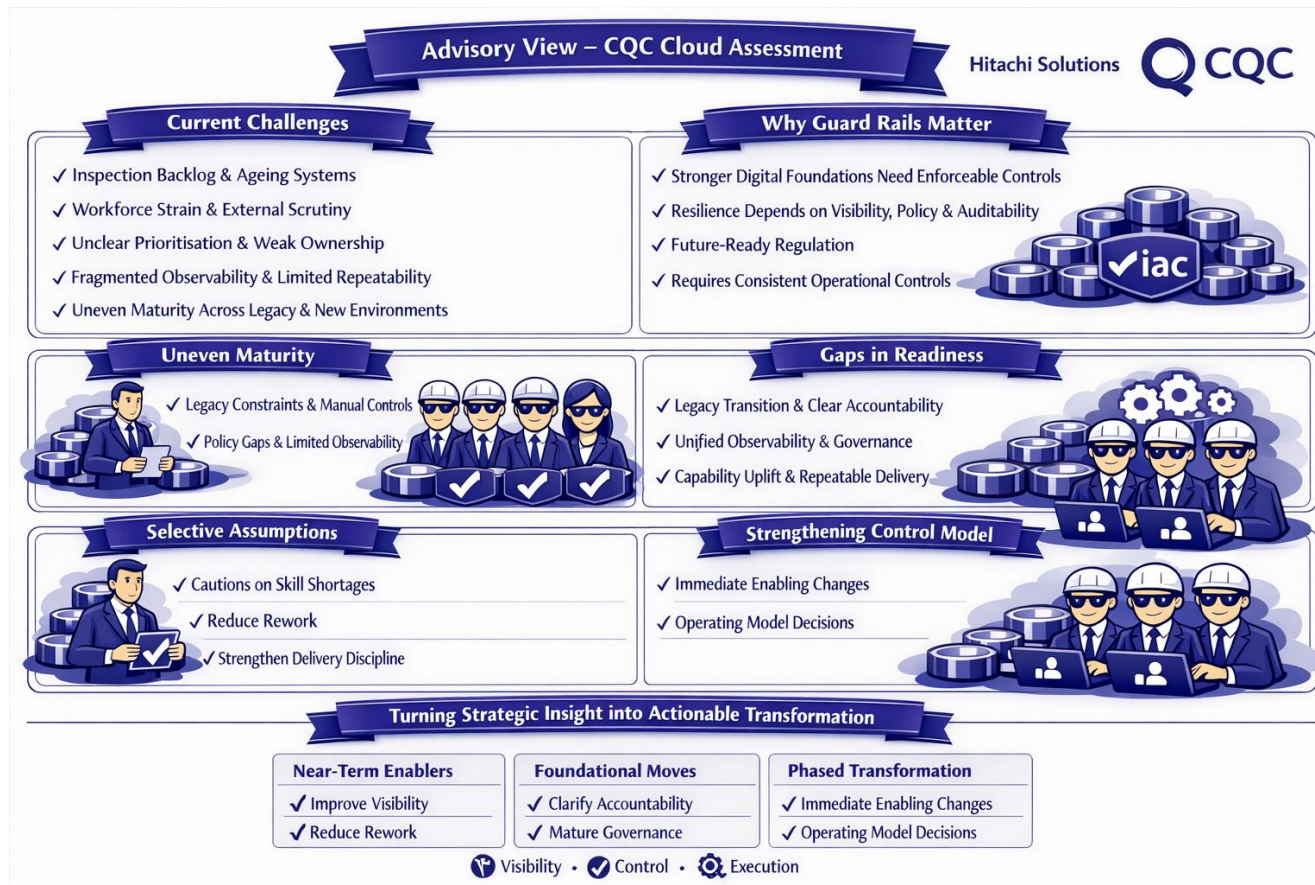


Control maturity is uneven across the estate. The new-world environment is more advanced on policy parameters and diagnostic settings, while the legacy estate remains inconsistent. The gap is not always technical inability. It is often the result of design choices, legacy constraints or cost trade-offs.

- **Activity logging.** Stronger in newer Azure areas, less complete elsewhere, partly for cost reasons. This weakens auditability and incident response where they matter.
- **Policy enforcement.** The main issue is turning written standards into technical enforcement. The estate needs stronger policy-as-code and pattern-based enforcement, especially where legacy still depends on manual interpretation.
- **Change control.** An established legacy strength, but one that operates through manual governance rather than built-in platform mechanisms.

Control improvement should be selective. CQC needs to decide where stronger controls matter first, especially where legacy and new-world services coexist.

Integrated advisory view



The strategy material and the assessment findings tell one story. CQC is trying to restore trust, improve performance and modernise its operating model while under pressure from backlog, ageing systems, workforce strain and scrutiny. What gets in the way today is consistent across the chapters: unclear prioritisation, weak ownership, inconsistent governance, fragmented observability, limited repeatability, and uneven maturity between legacy and new environments.

The cloud assessment is therefore an enabling intervention, not a technical review in isolation. The sequencing is clear:

- **Early moves.** Improve visibility, reduce rework and strengthen delivery discipline.
- **Heaviest work.** Legacy transition, observability, governance maturity, clearer accountability and capability uplift.

Cloud Governance

Current State Overview

CQC's Azure governance is in a known transitional state. The estate runs in a single Entra tenant but spans three parallel management-group hierarchies - legacy, "old CAF", and the new CQC CAF-aligned target - totalling 36 management groups, 65 subscriptions, 566 resource groups and 7,839 tenant-wide resources. The new CQC CAF hierarchy has been confirmed as the future model and is operational, but the bulk of running workloads remain in the legacy and old-CAF branches.

The transition is consequential rather than cosmetic. Policy inheritance, RBAC scope, tagging enforcement, FinOps accountability and decommissioning all currently behave differently depending on where a subscription sits in the hierarchy, which means governance outcomes are determined by historical placement rather than by current intent. The Cloud Centre of Excellence and platform team have established the right target patterns; the remaining work is to retire the legacy paths and embed ownership.

Governance Pillars

This assessment evaluates governance posture through four pillars:

- **Cloud Structure** - management-group hierarchy and subscription organisation.
- **Cloud Guardrails** - policy enforcement, compliance standards, and tagging hygiene.
- **Cloud Onboarding & Operating Model** - subscription-vending lifecycle, drift remediation, and administrative privileges.
- **Data Governance** - residency, classification, encryption and lifecycle standards for data assets.

A. Cloud Structure

CQC operates a single Entra tenant, but governance is split across three parallel management-group hierarchies: a legacy tree, an interim "old CAF" tree, and the new CQC CAF-aligned target. The new hierarchy has been confirmed as the future model and is live, yet the majority of running workloads still sit in the two older trees. Workshops framed this as an operating-model and ownership question rather than a technical constraint: the target patterns are right, and the work that remains is to retire the legacy paths and embed clear ownership of placement decisions.

Parallel Hierarchies

- Three active hierarchies govern one tenant at the same time, so policy inheritance, RBAC scope, tagging and cost accountability all behave differently depending on where a subscription sits. Governance outcomes are set by historical placement rather than current intent.
- The new CQC tree is correctly structured to CAF (Landing Zones, Platform and Sandbox) but holds only a handful of platform subscriptions today. The empty Corp and Online groups are reserved capacity awaiting application migration.
- Both older trees remain fully operational and continue to accrue new resources, widening the gap with every month that passes.
- The legacy structures cannot be removed without a planned retirement runway, estimated through workshops at approximately eighteen months.

Fragmented Legacy Estate

- The legacy estate was never designed as a single coherent structure. Subscriptions were created at different times by different teams and grouped by environment (prod and non-prod) rather than by workload, which is misaligned with Microsoft CAF guidance.
- Over half of the legacy estate is concentrated in five ATOS-era subscriptions, originally stood up as migration landing zones and never broken apart. This makes it hard to isolate workloads, assign ownership, or decommission anything without first mapping the full dependency chain.
- The result is no single view of who owns what, no consistent way to apply controls, and no reliable basis for attributing cost to a service or team.

Naming and Tagging Gaps

- A CAF-aligned naming convention is established and documented in the Cloud Centre of Excellence, and tagging standards are enforced in the new environment.
- In the legacy estate, ownership, cost-centre and data-classification tags are effectively absent, and the environment tag, although widely applied, uses inconsistent values, with several casings of prod, dev and sandbox in use at once.
- Without consistent tags, cost allocation, ownership resolution and classification-driven controls cannot attach to legacy resources.

Tagging is Rich but FinOps-Blind

- Legacy resources are heavily tagged, and the keys in use capture the right intent: service owner, service name, cost code and data classification.

- The keys do not match the canonical names that Azure Cost Management and policy-driven controls expect, so cost allocation, ownership resolution and classification all fail to attach despite the tags being present.
- Data classification is one of the missing canonical tags, which links directly to the findings in D. Data Governance.

Empty Management Groups

- Eight management groups are empty, but they fall into two distinct populations. Around half are CAF scaffolding awaiting subscription migration and should be retained; the rest are legacy artefacts that should be removed in the retirement wave.
- Reporting them as a single number obscures which are intentional and which are residue.

Transitional Landing Zone

- The new world is being built in code under the CQC management group, with subscription vending, baseline networking, key vault, storage and RBAC.
- The old world remains in place and holds the majority of running workloads, with iterative segmentation, audit-only policies and a partner-managed firewall.
- Identity runs on the single Entra tenant with directory sync to a legacy on-premises Active Directory, whose synchronisation direction was not confirmed at the workshop.
- Regional capacity adds pressure: UK South is constrained today and UK West is not a clean secondary, which complicates resilience planning during migration.

Lift and Shift Debt

- The estate carries a heavy "lift and shift" legacy, roughly split between PaaS and IaaS, with a meaningful slice of compute still running on virtual machines.
- It is large and diverse, spanning compute, integration, data and storage services, and modernisation must be paced against the rebuild programmes (AIS, EDP, Reg Platform) rather than run as a separate exercise.

Failure of Decommissioning

- A significant volume of orphaned and stale resources persists: failed or disconnected private endpoints, orphaned Application Insights instances, publicly reachable function apps with no private endpoint, empty subscriptions, and integration-services subscriptions stuck mid-decommission. A 2020 proof-of-concept subscription also remains as a dumping ground.
- This creates operational toil, audit drag and direct cost waste, and more importantly it masks live exposures by blurring the line between resources that are genuinely in use and those that should have been removed.

B. Cloud Guardrails (Policy & Compliance)

CQC has moved from an audit-only legacy posture to default enforcement in the new CAF environment. Since late 2024, new policies are enforced without exception, including restrictions such as preventing resource creation outside the UK and blocking public access to storage accounts, with compliance tracked at management-group level. A cloud working group owns policy decisions and management-group structure, with final approval routed through internal technical governance and a designated technical decision-maker. The primary compliance driver is the **NHS DSPT** (*Data Security and Protection Toolkit*), aligned to the **NCSC CAF** (*Cyber Assessment Framework*) and underpinned by NIST-aligned controls. CQC is not ISO or Cyber Essentials certified, and DSPT failure would cut access to patient data. Policy documentation remains limited, with the platform team owning ongoing maintenance and communication.

Guardrails Are Not Yet a Consistent Control Layer

- CAF guardrails are enforced by default in the new environment but do not yet operate as a consistent, tenant-wide control layer.
- Enforcement varies by placement. Legacy and old-CAF subscriptions inherit from different scopes, and some assignments sit below management-group level, weakening their effect as enterprise guardrails.
- Policy governance is immature: documentation is incomplete, exception handling is not centrally governed, and ownership is implicit.
- Policy outcomes track subscription placement rather than governance intent, and assurance relies on point-in-time evidence rather than repeatable mechanisms.

Policy Documentation and Communication

- Documentation of the enforced policies and their rationale is currently limited, which makes it harder for internal teams and third-party partners to understand and comply with the controls in force.
- The platform team owns policy maintenance and communication. The planned approach is to generate policy documentation as markdown directly from the policy code and publish it to internal and third-party teams, so the published guidance stays aligned to what is actually deployed.
- Until this is in place, assurance depends on individual review rather than a current, published control catalogue, and partners operating inside the tenant cannot reliably self-serve the policy set they are bound by.

Secure by Design Review for New Workloads

- New workloads are governed through a "secure by design" review involving security and TDA representatives, providing a preventive checkpoint before resources are provisioned. This complements policy enforcement by catching design-level issues that policy alone does not detect.

- The review is not yet underpinned by a formal logging and monitoring standard, so its outcomes depend on reviewer judgement rather than a documented baseline. Legacy workloads predate this process and did not pass through it. (See Platform Operations and Observability.)

Direct under Tenant Root

- Two subscriptions sit directly under the Tenant Root Group with no management-group policy or RBAC. They are the only fully unconstrained subscriptions in the tenant, carry the most exposure in the estate, and are the simplest to fix by relocating them under Platform / Management.
- Around 89% of critical "deny" breaches originate from four storage-account policy initiatives across 39 subscriptions. The remediation lever is equally concentrated, so the storage-account programme clears most breaches with no other domain work required.
- The estate's most serious policy exposure is concentrated rather than spread, which makes it tractable: a small number of targeted actions removes the majority of the risk.

C. Cloud Operating Model & Cloud Onboarding

Subscription vending is automated in code for the new CAF environment, provisioning key vault, storage, networking and RBAC as part of landing-zone setup, with the platform team as the central point for onboarding and resource provisioning. The platform team also owns infrastructure deployments, policy management and module maintenance, and the operating model is evolving from a historically informal approach towards a controlled, documented process. Plans are in place to formalise the request route through ServiceNow. The outstanding gaps are in lifecycle governance: decision gates, standard patterns and offboarding are not yet consistently embedded.

Subscription Vending: Defined but not in practice

- Vending is automated in code and provisions key vault, storage, networking and RBAC, but operational intake is still manual, initiated through informal DevOps requests rather than the target ServiceNow-driven form with pre-approved archetypes and patterns.
- Vended subscriptions are not always provisioned into the correct management-group structure, so placement still requires manual correction after creation. This was identified as a fix to the vending process.
- Lifecycle governance is incomplete. Clear decision gates and standard patterns are not consistently applied, and offboarding is not yet defined. Legacy offboarding is especially hard because there is limited clarity on what is actually in use.
- As a result, onboarding and placement decisions are less repeatable and less auditable than required, and the absence of defined offboarding drives long-term drift and technical debt.

Operating Model Accountability Is Not Yet Defined

- The operating model defines how subscriptions are vended, but not who prioritises competing work across the rebuild. AIS, EDP, Reg Platform, security remediation and platform migration draw on the same people and change windows, with no single authority sequencing them. Prioritisation is the dominant blocker identified in the Cloud Strategy analysis.
- No single technical authority holds the pen on the digital rebuild, so tactical delivery decisions are made workstream by workstream rather than against a shared sequence and dependency map.
- Service ownership is unresolved. Most legacy workloads have no run or service team, so operational responsibility defaults to the platform team, which is overloaded with first-line triage that should sit with service owners (see Platform Operations and Observability).
- The platform mechanics are improving, but without a defined accountability and prioritisation layer the estate becomes busier without becoming more governed.

- **The Prioritisation Problem:** Without a mechanism for deciding what comes first, tactical fixes accumulate without building towards the target state. Security remediation competes with platform migration. AIS cost reduction competes with AIS rebuild. Decommissioning is deferred because no one owns the decision to stop. The result is an estate that gets busier without getting better.

Privileged Access Surface

- The estate carries 355 Owner role assignments, of which 194 are service principals and 63 are user accounts, with the remainder assigned to groups. The concentration of service-principal Owner grants increases blast radius from pipeline compromise and is inconsistent with the least-privilege posture defined in the CAF target.
- Owner usage has not been subject to a deliberate rationalisation exercise to date.
- A dedicated mg-decommissioned management group exists, holding three subscriptions, but the rate of retirement is not keeping pace with the technical debt accumulating in the legacy tree.

Failure of Decommissioning

- Twenty private endpoints are failed or disconnected, sixteen of them in CQC DEVTST VDC2. Eighty-six Application Insights instances are orphaned with no linked application or telemetry. 158 function apps are publicly reachable, of which only two have private endpoints. Eight management groups and eleven subscriptions are empty.
- Eight integration-related subscriptions are targeted for decommissioning, the four named "CQC Integration Services" and four "GFC" subscriptions. Only one resource group across the integration-services set is still in use and is being moved to its own subscription. The "Hitachi Dev UK" subscription (29 resource groups) remains as a proof-of-concept dumping ground from 2020.
- The underlying driver is the absence of a teardown discipline: resources were deployed and left rather than destroyed once finished with, so orphaned assets accumulated across the estate.
- The volume of orphaned and stale resources creates operational toil, audit drag and direct cost waste. More importantly, it masks live exposures by making it harder to distinguish resources that are genuinely in use from those that should have been removed.

The Prioritisation Problem

- The blocker analysis in the Cloud Strategy chapter identified prioritisation as the dominant risk category. CQC is under pressure from multiple directions at once: inspection backlog, ageing systems, workforce strain, regulatory scrutiny, and the need to modernise while keeping services running. The natural response is to push on all fronts simultaneously. The evidence suggests that this is exactly what is happening, and it is creating fragmentation rather than progress.
- Without a mechanism for deciding what comes first, tactical fixes accumulate without building towards the target state. Security remediation competes with platform migration. AIS cost reduction competes with AIS rebuild. Decommissioning is deferred because no one owns the decision to stop. The result is an estate that gets busier without getting better.

D. Data Governance

Data residency, classification and protection standards are recognised as critical within the CQC environment, given its regulatory and assurance obligations. Technical controls exist, but from a governance perspective the definition and enforcement of data classification and ownership standards are still maturing. The absence of consistently governed classification and ownership models limits CQC's ability to enforce policy-driven controls and demonstrate assurance at scale. The need here is for clearer governance ownership rather than purely technical remediation.

Data Governance Recognised, Ownership Not Yet Embedded

- CQC recognises data as a critical asset, with explicit obligations around protection, residency and regulatory assurance, acknowledged in the cloud strategy and assessment activities.
- Enterprise-wide ownership for data classification, stewardship and lifecycle governance is not yet formalised, and controls rely on local implementation rather than central governance.
- Assurance therefore depends on point-in-time evidence rather than repeatable governance mechanisms.

Classification Standards Exist, Enforcement Inconsistent

- Classification is recognised as necessary to support policy-driven controls and regulatory assurance, but it is not yet governed as a mandatory, enforced standard across cloud workloads.
- Tagging standards are well established at resource-group level but are not consistently used to represent data classification or sensitivity, and classification is not enforced at onboarding or workload placement.
- As a result, data protection controls cannot be reliably aligned to sensitivity or regulatory requirements, and demonstrating consistent compliance across the estate is harder than necessary.

Residency and Regulatory Requirements Governed Implicitly

- Residency and sovereignty requirements are understood and generally respected through architectural and platform decisions, but they are implicitly applied rather than explicitly governed.
- There is limited evidence of centrally documented standards, exception processes or ownership for ongoing assurance, so compliance depends on architectural intent rather than formal governance artefacts.
- Exceptions are therefore harder to assess, approve and evidence consistently.

Hybrid Data Governance Increases Assurance Effort

- Data governance operates in a hybrid state where intent is clear but enforcement and ownership are uneven across legacy and CAF-aligned environments.

- This is a transitional state rather than a lack of awareness, but it increases the manual effort required to demonstrate assurance and respond to audit or regulatory queries.

Purview Two-Portal Split

- Two Microsoft Purview instances exist: dev/test on the new portal and Production on the old portal. Migration to the new portal is blocked because no one at CQC currently holds the access required to resolve it. Purview is also a one per tenant resource so only one needs to persist in the future state.
- Hugh Gordge, the Purview administrator, is working towards consolidation, and Robert Hawker has set a clear intent to extend Purview's footprint, particularly to flow sensitivity labels into Microsoft Fabric.
- Until Production is migrated, the catalogue is inconsistent across environments, classification and labelling cannot be driven from a single authoritative source, and sensitivity-label propagation into Fabric is blocked.

GDPR Retention Vacuum

- Sensitivity labels are not yet operationalised. NHS Employee Service Record (ESR) data is GDPR-sensitive but held in an "Interim SA" storage account that retains all employee data indefinitely with no retention policy.
- APIM handles GDPR-sensitive data through SOAD via manually triggered processes.
- GDPR retention non-compliance is a live exposure, and no enforceable classification currently drives downstream controls.

Recommendations

Cloud Structure

- **Consolidate onto the New CAF CQC Hierarchy:** make the new CAF-aligned tree the single management-group hierarchy and retire the legacy (mg-cqc-legacy) and old-CAF (mg-cqc-root) trees, freezing new placement under both so neither keeps growing.
- **Formalise and Prioritise the Legacy Migration:** sequence the larger legacy and VDC migration on its longer retirement runway, breaking the VDC concentration apart workload by workload.

Cloud Guardrails

- **Refresh Policy Definitions:** promote audit-mode legacy policies to enforced mode under the New CAF management group; align to CIS, NIST and UK NHS packs.
- **Track Compliance Uplift:** set a 30/60/90-day remediation cadence per subscription; target 80% overall compliance within twelve months.
- **Formalise Policy Ownership:** define clear ownership for policy definition, approval, exception handling and lifecycle management.

- **Publish the Policy Catalogue:** generate policy documentation as markdown directly from policy code and publish it to internal teams and third-party partners, kept in step with what is deployed.
- **Back the Secure by Design Review:** support the secure-by-design review with a documented logging and monitoring standard, so review outcomes follow a baseline rather than reviewer judgement (see Platform Operations and Observability).
- **Embed FinOps Guardrails:** introduce policy-enforced ownership and cost-allocation tags aligned to a defined FinOps accountability model.

Cloud Operating Model

- **Approved Onboarding Patterns:** publish a small, fixed set of approved subscription archetypes and landing-zone patterns covering configuration, placement, tagging and RBAC. Treat requests that conform as pre-approved standard changes, and route only non-standard requests to CAB.
- **ServiceNow Vending Intake:** replace the “DevOps request” route with a ServiceNow-driven vending form within ninety days.
- **Embed Platform Ownership:** assign accountability for onboarding standards, tooling and lifecycle management to the platform team, with formal governance checkpoints for subscription creation and workload placement.
- **Rationalise Owner Role Assignments:** audit the numerous ‘Owner grants’ (particularly the service-principal grants), reduce to named exceptions, and require documented justification for new Owner-scope assignments.
- **Technical Program Leadership:** Establish a group to own the prioritisation. (See more in chapter ‘Tech Program Leadership’)

Data Governance

- **Consolidate Purview:** recover production access and migrate to the new portal; appoint a named administrator.
- **GDPR Retention:** apply retention policies to the Interim SA and to all ESR-bearing storage; surface deletion as a programme action.
- **Define Data Ownership:** establish clear accountability for data classification, stewardship and lifecycle governance at platform and workload levels. Operationalise data classification and sensitivity labelling, enforced consistently across EDP, Fabric and downstream services.
- **Document Residency and Sovereignty:** define residency expectations, approval processes and exception handling to support audit and assurance.
- **Align with CAF Controls:** ensure data governance standards directly inform policy, tagging and onboarding decisions rather than operating in parallel.

Networking and Security

Current State Overview

CQC's networking estate is structurally legacy. A single central firewall hub serves multiple environments. Private DNS zones are sprawled. The IP plan was historically allocated by spreadsheet, with oversized ranges and hundreds of unused subnets. The new-world design exists in code on paper but is not yet deployed.

Network Topology

Hub and Spoke Topology

- The topology resembles a hub-and-spiderweb rather than a true hub-and-spoke. A single Azure Firewall hub serves prod, dev and UAT, with ExpressRoute, VPNs, App Gateways and spokes all peered in.
- Spokes are joined laterally to one another. Lateral traffic patterns are unpredictable and segmentation is reactive rather than designed.
- The topology is not in code. The firewall ruleset is third-party managed, contains thousands of unaudited rules, and has no owner-of-record. A single ruleset spanning all environments concentrates change risk.
- Legacy rules will not be migrated.

Region Concentration and UK West Reality

- Around 86% of resources are in UK South. Microsoft has confirmed that UK South is capacity-constrained and has asked CQC to provide advance notice when additional compute is needed.
- Quoted lead times are "10 days for simple, six weeks for complex", with one open request currently at ten weeks. Scaling in UK South is no longer on-demand.
- UK West does not offer a straightforward alternative. The region is limited to a single availability zone, ruling it out as a resilient secondary for zone-redundant workloads.
- The result is a strategic dependency on a constrained primary region, with no validated secondary and no active DR posture.

Isolated VNets

- Many VNets are isolated with no peering, no gateway, and no productive traffic.
- They consume IP address ranges and management effort for no return.

Network Security and Traffic Management

WAF and APIM

- App Gateway with WAF v2 sits in front of APIM. The WAF runs the default managed rule set only, with no geo-restrictions, no throttling, and no custom rules.
- In its current configuration the WAF does not actively block malicious traffic. The APIM scraping incident, in which tens of millions of API calls per month were scraped through unprotected endpoints, is a direct consequence.
- Four Premium APIM instances run today, one per environment. Pre-prod environments are significantly underused relative to the Premium SKU cost.
- Hardcoded JWT token values appear in APIM policies alongside embedded business logic, creating an exfiltration and rotation risk on the tokens and a fragile change surface in the policy layer.

NSG Coverage

- The legacy environment does not consistently apply Network Security Groups. Coverage is low across the estate.
- Segmentation is reactive rather than policy-driven. Lateral movement between resources is constrained by chance rather than by design.
- Six NSGs allow RDP and one allows SSH inbound from any internet source, exposing management ports directly to the public internet.

Private Endpoints and DNS

- Private Endpoints and DNS zones have proliferated with significant duplication. Many private DNS zones are duplicated per Private Endpoint of the same type.
- A number of Private Endpoints are in a failed or disconnected state.
- DNS and Private Endpoint management is itself a cost and operational drag.

Hybrid Connectivity

ExpressRoute

- Two ExpressRoute circuits operate today. The first connects to the legacy on-premises data centre and is being decommissioned by end of year as the data centre closes. The gateway will be retained because it now serves Azure VMware Solution (AVS).
- The second connects to HSCN (Health and Social Care Network) and is being retained.
- AVS is a short-lived bridge, with strategic intent to decommission. The data-centre exit is a hard timeline, with AVS acting as a short-window safety net.

Third-Party Organisations Within the Tenant

- MNSI (Maternity and Newborn Safety Investigations) and a small number of other organisations sit inside the CQC tenancy with no dedicated subscriptions.
- This extends the lateral-movement blast radius across organisational boundaries and introduces regulatory ambiguity around responsibility and accountability.

Pulse Secure VPN for Siebel

- Infosys reaches the Siebel CRM back-end via a Pulse Secure VPN that terminates on a VM in the hub, presented externally.
- The VPN concentrator on a VM in the hub is a fragile control plane. Siebel migration to Azure is targeted for August to September, at which point this dependency is expected to be retired.

Core Services

Public DNS

- DNS for the CQC public domain is externally managed by Vodafone. Internal DNS is still served by legacy AD domain controllers.
- Hundreds of private DNS zones exist, many duplicated per Private Endpoint type.
- Azure DNS is positioned as the target primary, but internal name resolution still depends on legacy infrastructure and public domain control is held by an external partner.

IP Address Management

- IP allocation was historically spreadsheet-based. The legacy estate carries oversized default ranges and a large number of unused subnets.
- An IPAM tool has since been implemented, and the new CAF subscription vending allocates ranges by environment tag with subnets sized to Microsoft best practice.
- The legacy address space carries waste and a latent risk of overlap with on-premises ranges.

Key Vaults

- Many Key Vaults allow public network access, use legacy Access Policies rather than RBAC, and have no diagnostic settings configured.
- Where RBAC is in use, scope is typically set at subscription or management-group level rather than the specific vault.
- Purge Protection is not enabled on over half of all vaults.
- There is no forensic capability if a secret is leaked.
- A Production Key Vault was observed with virtual-network links to both dev and prod environments. While a legitimate case exists for a shared SSL certificate vault, the cross-environment link breaks the environment boundary that policy is otherwise trying to enforce.

Storage Accounts

- Many storage accounts allow public network access. A significant number allow anonymous blob or container access.
- Shared Key authorisation remains enabled on most accounts. A small number still allow TLS 1.0.
- Compliance against the secure-transfer policy is critically low.
- This represents a direct exfiltration surface and an immediate compliance failure.

Recommendations

Firewall

- **One firewall per region in the New CAF:** legacy rules retired on a hard sunset; rule estate in code as part of a Firewall Policy resource. Consider segregating per environment
- **Audit the Firewall Ruleset:** rationalise the ruleset before migration and assign an internal owner-of-record for all firewall rules going forward. Move to Azure Firewall Policy instead of existing Classic rules to improve flexibility.

Network Topology

- **Deploy Hub-and-Spoke in Code:** stand up the new-world hub-and-spoke topology as code and eliminate lateral spoke-to-spoke peering. Consider segregating fully per environment.
- **Reclaim Isolated VNets:** decommission or repurpose isolated VNets and reclaim the unused IP address space.

Region and DR

- **Formalise UK South Capacity Management:** establish a capacity-management process for UK South, including advance notice to Microsoft for planned scaling events.
- **Validate a Secondary Region Strategy:** define the minimum viable DR posture and test failover. Consider Azure Frontdoor if a multi-location environment is to become the norm.

WAF and APIM

- **Harden the WAF:** add custom rules, geo-restrictions and rate limiting, as the default rule set alone is insufficient.
- **Right-Size and Secure APIM:** right-size APIM SKUs per environment, remove hardcoded JWT values from APIM policies and externalise token management.

NSG and Segmentation

- **Enforce NSG Coverage:** mandate NSGs on all subnets via Azure Policy, prioritising the hub VNet and production spokes. Enforce minimal ruleset with Deny All rules to ensure only the necessary traffic is allowed.
- **Design Segmentation to Zero Trust:** move from reactive segmentation to a designed, policy-driven model aligned to Zero Trust principles.
- **Lock Down Exposed Management Ports:** remove the internet-facing RDP and SSH allow rules, six on 3389 and one on 22, and require Azure Bastion with Just-in-Time (JIT) access for all administrative connections to virtual machines.

Private Endpoints and DNS

- **Consolidate Private DNS and Endpoints:** consolidate duplicated private DNS zones and remediate failed or disconnected Private Endpoints. Consider using App Service Environment as an alternative to Private Endpoints to reduce resource volume.
- **Centralise DNS under Azure DNS:** make Azure DNS the single authoritative source for name resolution or move to a Private DNS Zone when linking into isolated Vnets.

Hybrid Connectivity

- **Complete ExpressRoute Decommissioning:** finish ExpressRoute decommissioning on schedule and confirm the AVS exit timeline.

External Exposure

Current State Overview

CQC's internet-facing surface is broad but lightly defended at the perimeter. The estate exposes a sizeable set of Public IP addresses, several Azure Firewalls and a number of Application Gateways, yet the controls that protect those entry points against volumetric attack and inspect traffic for threats are either absent or set to their lowest tier. No public address sits behind a managed DDoS plan, every firewall runs on the Standard tier with no advanced inspection, and a small number of legacy address objects remain on a retiring SKU. The Web Application Firewall posture is addressed in the Networking and Security chapter; this chapter covers the exposure that sits in front of it. For a public-facing regulator, the perimeter is the part of the estate most visible to an external actor and currently the least protected.

No Managed DDoS Protection

- No Public IP address in the estate is protected by a managed DDoS Standard plan. Protection relies entirely on the platform-level basic tier that Azure applies to every tenant.
- The basic tier provides no per-resource alerting, no attack telemetry and no post-incident reporting. A volumetric or protocol-level attack against a CQC service could not be detected, scoped or evidenced.
- The internet-facing Application Gateways that terminate TLS for CQC services carry no dedicated protection, leaving the most exposed entry points without managed mitigation.

Public IP SKU Posture

- Almost all Public IP addresses are on the modern Standard SKU, which is the correct posture for zone redundancy and resilient networking.
- A small number remain on the legacy Basic SKU, which Microsoft has scheduled for retirement. These require migration to Standard before the deadline.
- At least one address is unassociated with any resource, accruing cost with no operational benefit, and should be released.
- Six Public IPs are attached directly to virtual machine network interfaces, exposing those machines to the internet with no Layer 7 inspection.

Firewall Tier and Inspection Gap

- The entire Azure Firewall estate runs on the Standard tier, with no instance on Premium.
- Standard tier provides no Intrusion Detection and Prevention (IDPS) and no TLS inspection, so internet-bound egress and encrypted traffic leave the estate uninspected.

- Firewalls are configured through inline rules, rather than Azure Firewall Policy which allows greater flexibility and simplifies rule reuse.
- The review rates the firewall posture as "Fair", held back by the missing advanced security capabilities. The hub firewall on the egress path is the priority candidate for a Premium upgrade with zone redundancy.

Recommendations

- **Enable DDoS Network Protection:** apply an Azure DDoS Network Protection plan to the virtual networks hosting internet-facing services, prioritising those fronting CQC's public Application Gateways and Public IPs. Configure per-resource alerting and attack telemetry so volumetric and protocol attacks can be detected, scoped and evidenced for assurance reporting.
- **Rationalise the Public IP Estate:** migrate the remaining Basic SKU addresses to Standard ahead of Microsoft's retirement deadline, release any unassociated addresses to remove idle cost, and enforce Standard SKU on new Public IPs through Azure Policy.
- **Upgrade the Hub Firewall to Premium:** move the egress-path hub firewall to Premium tier to enable IDPS and TLS inspection, adopting zone redundancy at the same time. Evaluate the remaining Standard-tier instances against measured egress traffic before committing to further Premium upgrades, so cost is not added where it is not justified. Move to modern Firewall Policy rules to allow greater flexibility.
- **Remove Direct VM Public IP Exposure:** remove the public IPs attached directly to virtual machine network interfaces and route inbound traffic through the Application Gateway and firewall, so all internet-facing access passes through Layer 7 inspection.

Secret & Key Management

Current State Overview

CQC operates a large Key Vault estate concentrated in the legacy VDC subscriptions and pre-platform workloads. The estate is recoverable but exposed. Soft Delete is enabled everywhere, yet the majority of vaults are reachable over the public internet, still use the legacy authorisation model, and lack the controls that would make a leaked secret recoverable and auditable. Secret management currently behaves as "internet-reachable by default", with network restriction and RBAC applied inconsistently across the estate. The new-world platform vaults are configured correctly, so the target pattern already exists; the work is to extend it across the legacy footprint.

Public Network Access by Default

- The majority of Key Vaults allow public network access, and only some sit behind Private Endpoints.
- Even where RBAC and firewall rules limit who can authenticate, the attack surface is large because the vaults are reachable from the internet by default.
- Vaults holding production and pre-production secrets carry the same exposure as development vaults, with no consistent network boundary separating them.

Legacy Authorisation Model

- Many vaults still use the legacy Access Policy model rather than RBAC.
- Access Policies sit outside the tenant's central identity governance. They cannot enforce Conditional Access, integrate with Privileged Identity Management, or provide the centralised auditing that RBAC offers.
- Where RBAC is in use, scope is frequently set at subscription or management-group level rather than the individual vault, which over-grants access beyond the vault that needs it.

Resilience and Forensic Controls

- Soft Delete is enabled on every vault in the estate. This is the one control that is consistent across the estate and gives a recoverable position even where other settings are weak.
- Over half of the vaults do not have Purge Protection enabled. Without it, a soft-deleted secret can be permanently purged before the recovery window expires, which undermines Soft Delete and creates a credible insider or compromised-identity attack vector.
- Diagnostic logging is not consistently configured, so there is limited forensic capability if a secret is leaked or misused.

Cross-Environment Vault Linkage

- A Production Key Vault was observed with virtual-network links to both development and production environments.
- A shared SSL certificate vault can be a legitimate pattern, but the cross-environment link breaks the environment boundary that policy is otherwise trying to enforce.

Recommendations

- **Disable Public Network Access:** Set public network access to disabled on all production and pre-production vaults, and front them with either Private Endpoints or isolated Vnets. Enforce the control through Azure Policy so new vaults are created closed by default.
- **Migrate to RBAC Authorisation:** Move the vaults on legacy Access Policies to RBAC, scoped at the individual vault rather than the subscription or management group. This brings vault access under Conditional Access and PIM.
- **Close the Resilience Gap:** Enable Purge Protection on higher environments, and configure diagnostic settings on all vaults so secret access is logged and auditable.
- **Resolve the Shared Vault:** Remove or isolate the cross-environment vault so the development and production boundary is restored, retaining a dedicated shared certificate vault only where there is a documented need.

Identity Management

Current State Overview

CQC's security and identity posture is built on a single Entra tenant administered by Littlefish. Microsoft Sentinel and Defender for Cloud are in place and operated jointly with NHS CSOC via Azure Lighthouse. The control fabric is strong on the detective side and weak on the preventive side. Standing privilege is the dominant blast-radius lever, break-glass discipline is informal, and Key Vault hygiene is uneven. The preventive layer is weak, segmentation is reactive rather than designed, and encryption is inconsistent across data tiers. Sentinel and Defender for Cloud are compensating for gaps that should be closed by preventive controls.

The gap is not unusual for an organisation in transition. CQC is carrying a legacy estate that was never designed with Zero Trust in mind alongside a new CAF environment where stronger controls are beginning to emerge. The challenge is to extend Zero Trust controls consistently across both, starting with the areas of highest risk.

Identity Infrastructure

Entra Tenant and Legacy AD Sync

- One Entra tenant ("Care Quality Commission") spans all subscriptions. A separate sandpit tenant exists under a different internal team.
- Directory sync exists with the legacy on-premises IMS Active Directory. The synchronisation direction (one-way or two-way) was not confirmed during the workshop.
- Legacy AD domain controllers still serve primary DNS for the IMS domain and for VPN clients.
- The new world will continue to use the existing tenant, which means it inherits the tenant's current identity debt.

Legacy Access in Production

- A number of Entra ID groups hold Contributor access to Production. At least one group is believed to belong to a previous delivery partner (KPMG) and remains active.
- A previous account-hygiene exercise identified a large volume of stale accounts.

Privileged Access

Global Administrator Accounts

- Four Global Administrator accounts exist. They are permanently active, with no approval required to activate and no alerting on activation.
- The current model relies on Sentinel as a detective rather than a preventive control. A compromised-admin scenario has no preventive gate.

Standing Privilege

- A significant volume of permanent Owner and Contributor assignments exist across subscriptions.
- Developers hold permanent Contributor on production in some areas, with Click-Ops changes routinely invalidating Terraform.
- A large number of Classic Administrators remain active, bypassing RBAC entirely.
- Standing privilege is the dominant blast-radius lever in the estate, and identity hygiene cannot improve while Click-Ops in production remains the operating model.

Guest Onboarding

- Guest onboarding is ad hoc with no consistent process. Some accounts are created directly, others as B2B.
- There are no visible Access Packages or Access Reviews for the guest lifecycle.
- Orphaned guests persist, and the risky-user portal accumulates alerts that are actioned but not cleared down.

Managed Identities and Automation

- Managed Identity adoption is recognised as the right pattern for resource-to-resource access.
- APIM correctly pulls named values from Key Vault rather than storing plaintext, and an automated App Gateway certificate process has been built.
- The estate cannot reach the new-world hygiene baseline while user-identity-backed flows persist.

Defender for Cloud and Sentinel

Defender for Cloud

- Defender plans were enabled across all subscriptions, including decommissioned and sandbox subscriptions, via manual portal toggling.
- Manual onboarding causes drift. Decommissioned and sandbox subscriptions generate cost waste with no security return.
- A large backlog of critical and high-severity Defender recommendations sit across the estate. Standing critical findings will largely retire with the legacy estate rather than be remediated in place.

Sentinel

- A single Microsoft Sentinel resource is operated by Ryan Torrance's team, supported by NHS CSOC via Azure Lighthouse.
- A use-case document links analytic rules to use cases with review cadence and testability. Some analytic rules sit in disabled or development state.

- Detective capability is strong, but the preventive layer (PIM, Conditional Access, break-glass) is not yet at parity. Sentinel is currently compensating for gaps that should be closed by preventive controls.

Recommendations

Identity Infrastructure

- **Confirm the Directory Sync Direction:** confirm and document whether the legacy AD sync is one-way or two-way, and plan for legacy AD decommissioning as the DNS and VPN dependencies are retired.
- **Migrate User-Identity Flows:** map all user-identity-backed Power Apps and Dynamics flows and migrate them to service principals or Managed Identities, unblocking the stale-account cleanup.
- **Remove Former Partner Access:** remove or re-validate all former partner access in Production, including the networking-level exceptions.
- **Extend PIM to Global Administrators:** bring all Global Administrator accounts under PIM with mandatory approval and alerting on activation.
- **Rationalise Standing Privilege:** rationalise Owner and Contributor assignments, remove Classic Administrators, and target a maximum of three Owners per subscription.
- **Eliminate Click-Ops in Production:** enforce deployment via pipeline only, so manual changes no longer override Terraform.

Guest Lifecycle

- **Govern the Guest Lifecycle:** implement Access Packages and Access Reviews for all guest accounts.
- **Clear the Risky-User Backlog:** clear down the risky-user portal backlog and define a standing triage cadence.

Managed Identities

- **Complete the Flow Migration:** finish migrating user-identity-backed flows to Managed Identities or service principals.
- **Scope Key Vault RBAC to the Vault:** scope Key Vault RBAC to individual vaults rather than subscription or management-group level.

Defender for Cloud

- **Right-Size Defender Coverage:** remove Defender plans from decommissioned and sandbox subscriptions.
- **Automate Defender Onboarding:** onboard Defender via policy to prevent configuration drift.
- **Triage the Recommendation Backlog:** triage and prioritise the critical and high-severity Defender recommendation backlog.

Sentinel and Preventive Controls

- **Close the Detective-Preventive Gap:** bring PIM, Conditional Access and break-glass procedures to parity with Sentinel coverage, so detection is no longer compensating for missing preventive controls.
- **Rationalise Analytic Rules:** review disabled analytic rules and either enable or retire them.

Zero Trust

What Zero Trust Means in This Context

Zero Trust is Microsoft's security model for modern cloud estates. It is not a product, a licence, or a one-off project. It is a set of design principles that shape how identity, access, networking, data and operations should behave across the entire platform.

Microsoft defines Zero Trust through three principles: **verify explicitly**, **use least privilege**, and **assume breach**.

These principles are not standalone. They are embedded into the two frameworks this assessment aligns to:

- **The Cloud Adoption Framework (CAF)** integrates Zero Trust into its Secure methodology. CAF expects Zero Trust thinking to be applied from strategy through to governance and management. The CAF Landing Zone design guidance references Zero Trust for identity controls, network segmentation, and data protection. CQC's new CAF-aligned hierarchy is the right structural foundation, but Zero Trust controls are not yet consistently applied across it.
- **The Well-Architected Framework (WAF)** treats Zero Trust as foundational to its Security pillar. Microsoft's WAF guidance states that a well-architected workload is built with a Zero Trust approach. The Security pillar evaluates workloads against the same three principles used below: whether identity is verified at every access point, whether privilege is minimised and time-bound, and whether the architecture limits blast radius in the event of compromise.

This section assesses CQC's current estate against those three principles. It does not introduce new findings. Every row in the tables below is drawn from the detailed technical chapters that follow. The purpose is to give the reader a single, consolidated view of where CQC stands against the security model that both CAF and WAF expect to be in place.

Zero Trust Assessment

CQC named Zero Trust as a target outcome. The estate is assessed below against Microsoft's three Zero Trust principles. No new findings are introduced; each draws on the technical findings already set out in this report.

Verify Explicitly *(always authenticate and authorise on all available data points)*

- Global Administrator accounts activate without approval or alerting, leaving no preventive gate.
- PIM is enforced selectively but not extended to Global Administrators, so coverage is only partial.
- Guest onboarding is ad hoc with no Access Packages or Access Reviews, so there is no lifecycle governance.
- A legacy partner group retains Contributor on Production, an unverified access path.
- A number of stale accounts cannot be cleaned up because they are tied to user-identity-backed flows, leaving orphaned identities in place.
- The directory sync direction is unconfirmed, leaving an unaudited identity surface.

- Hitachi engineers were issued CQC user accounts rather than B2B guests, crossing the identity boundary.

CQC cannot verify explicitly while identity lifecycle is ungoverned, privileged access is permanent, and former partner access persists without dependency mapping. The estate relies on detective controls rather than preventive gates to manage identity risk.

Use Least Privilege (*limit access with just-in-time, just-enough-access and risk-based policies*)

- Excessive permanent Owner assignments exist across subscriptions, a structural standing-privilege problem.
- Classic Administrators bypass RBAC entirely, a legacy bypass.
- Developers hold permanent Contributor on Production, sustaining Click-Ops in production.
- Multiple subscriptions have more than three Owners, leaving them over-provisioned.
- Individual users carry a high average of role assignments, some with twenty or more, indicating privilege accumulation.
- Key Vault RBAC is scoped at subscription or management-group level rather than the vault, over-scoping access.
- The bootstrap subscriptions inherit no management-group policy or RBAC, leaving them fully unconstrained.
- Service principals hold admin role assignments at scale, a machine-identity over-privilege.

Least privilege is the weakest of the three principles in the current estate. Standing privilege is structural rather than incidental. It cannot be resolved while Click-Ops in production remains the operating model, Classic Administrators persist, and Owner grants are not subject to deliberate rationalisation.

Assume Breach (*minimise blast radius, segment access, and verify end to end*)

- Network segmentation is reactive rather than designed, so lateral movement is constrained by chance rather than by policy.
- Standing Owner and Contributor grants and active Classic Administrators give any compromised identity a wide blast radius.
- Encryption is inconsistent across data tiers, with the AI workloads holding the most sensitive data on the weakest key model.
- Key Vaults are largely reachable from the public internet, many lack Purge Protection, and diagnostic logging is inconsistent, so a leaked secret may be neither contained nor traceable.
- Break-glass discipline is informal, and one B2C tenant is potentially locked out with no break-glass cover, so there is no tested recovery path.
- Backup coverage is uneven, with suspended and failed items and Cross-Region Restore disabled, so recovery from a destructive event is not assured.

Assume Breach is undermined by wide standing privilege, weak segmentation and uneven data protection. The detective layer would observe a breach, but the estate does little to limit how far it could spread or to guarantee recovery.

Platform Operations and Observability

Current State Overview

The operations estate is fragmented along the same fault line as governance. There is no single Log Analytics workspace. There is no single dashboard. Alerts and action groups are duplicated, disabled or routed inconsistently. Application Insights coverage is patchy and ownership is unclear. The platform team is, by default, the "everything team" for legacy workloads. Sentinel and Defender for Cloud sit on top of this fragmented foundation and inherit its blind spots.

Azure Monitor and Log Analytics

Workspace Proliferation

- Log Analytics workspaces have proliferated with no logical structure. Some subscriptions have more than one.
- This drives duplicated ingestion costs, fragmented querying, and gaps in visibility.
- A significant proportion of Application Insights instances are not linked to any workspace, creating data islands invisible to the SOC.

Retention and Ingestion Cost

- Default retention is 30 days on most production workspaces, below the organisation's own 90-day policy.
- Enforcement is inconsistent. Several resources sit well below the policy minimum.
- Ingestion cost outweighs retention by roughly 10x. Reducing retention without an ingestion contract is a false economy.

Diagnostic Settings

- The majority of resources have no diagnostic settings configured.
- Without diagnostic settings the SOC has no ingestion path, Defender alerts cannot correlate against logs, and forensic investigation is severely degraded.
- This is recoverable via a single policy applied at Management Group scope.

Alerting

Alert Volume and Severity

- A large number of alert rules are deployed, but a notable proportion are disabled with no record of why.
- Several enabled rules have no action group attached. They log but never notify.
- High-severity alerts dominate the rule set with no graduated escalation model. The result is alert fatigue with poor signal-to-noise.

Action Group Routing

- Action groups are spread across the estate with inconsistent configuration.
- Some have no receivers configured. They fire into nothing.
- ServiceNow integration relies on generic webhooks rather than the native Azure ITSM connector, weakening schema mapping and removing round-trip acknowledgement.
- Some action groups point to single individuals with no holiday or sickness cover.

Workload Monitoring

Availability Tests

- Availability tests exist but the majority probe from too few locations to distinguish a real outage from a single-region probe failure.
- Cadence is too slow on most tests, giving worst-case detection latency of nearly half an hour.
- Tests are resource-centric rather than service-centric, with no linkage to SLOs and unclear ownership.

Dashboards

- Dashboards exist but over half carry only auto-generated names with no human-readable title.
- All are resource-centric rather than service-centric. Dashboards seems to not be deployed via IaC.
- There is no published "front door" dashboard set per landing zone.

Security Monitoring

- Defender for Cloud is active on most subscriptions but a small number are entirely disabled and produce no signal.
- The majority of subscriptions score below 60% Secure Score.
- A large volume of high-severity recommendations remain outstanding, led by permanent privileged roles, internet-exposed applications, and service principals with admin roles.
- No formal logging and monitoring standard has been published.

Operational Integration

- There are no run teams or service teams for most legacy workloads.
- All alerts default to the central platform mailbox.
- Tier definitions exist but are not linked to operational responsibilities.
- Mean-time-to-detect and mean-time-to-resolve are not measured.
- The platform team is overloaded with first-line incident triage that should belong to service owners.

Recommendations

Azure Monitor and Log Analytics

- **Consolidate the Workspace Estate:** consolidate to a single PLZ-aligned hub workspace plus a Sentinel SOC workspace, deploy AMPLS, and retire legacy workspaces by attrition.
- **Set Unified Ingestion and Retention Standards:** Define an ingestion contract per workload tier and a single, consistent retention model across all workspaces, using archive tiers where workload or compliance needs justify longer retention; keeping the estate consistent and cost-efficient.

Alerting

- **Adopt AMBA Alert Baselines:** adopt AMBA(Azure Monitor Baseline Alerts)-aligned alert baselines per tier, enforce them via Azure Policy, and separate platform from application alerts.
- **Fix Alert Routing:** remove external and personal-mailbox recipients and route all production alerts to monitored CQC distribution lists.
- **Deploy Service Health Alerts:** deploy a baseline Service Health alert per subscription via policy, since current coverage leaves most teams blind to Microsoft-declared incidents.

Workload Monitoring

- **Strengthen Availability Testing:** implement Tier-1 multi-region availability testing chained to an action group and a ServiceNow incident.
- **Move Dashboards to Code:** rationalise dashboards into IaC-deployed Workbooks.

Security Monitoring

- **Publish a Logging and Monitoring Standard:** publish a logging and monitoring standard owned by the security operations team.

Operational Integration

- **Establish Run and Service Teams:** Stand up Run and Service teams per domain with clearly aligned ownership tags and defined escalation SLAs, ensuring every alert has a known owner and a deterministic routing path from signal to responder.
- **Close the Detection-to-Resolution Loop:** Treat alerting, ITSM integration, and operational response as a single end-to-end flow rather than isolated capabilities, confirm that each alert maps to an owning team, a routing rule, an action group, and a resolution path, so coverage is consistent and fit for purpose across all domains.
- **Standardise ITSM Integration:** Migrate from the current webhook-based ServiceNow integration to the native ServiceNow Azure connector, and govern action groups by consistent naming and ownership. This provides bi-directional incident sync, reliable acknowledgement and resolution timestamps, and removes the fragility of custom webhook handling.

Workloads

Application Services

Application services (API Management, Function Apps, Logic Apps and App Service Plans) are the PaaS surface through which CQC delivers most of its regulatory services. The estate is large, publicly exposed, carries no platform authentication, and sits entirely on the management-group branches scheduled for retirement, with nothing yet built under the live CQC target.

Unauthenticated, Public Integration Gateway

- Every API Management instance is publicly reachable with no gateway authentication configured. As the primary external integration surface for CQC's services, this is the estate's highest-priority application security gap.
- Premium capacity is spread across non-production environments, while a production workload runs on a Developer tier that carries no service-level guarantee. The whole footprint sits on the retiring hierarchies rather than the live target.

Open Function App Estate

- The Function App estate is the largest serverless footprint in the tenant, and almost all of it is open to the public internet with no platform authentication on any app. Access depends entirely on long-lived function keys, with no conditional access and no audit trail.
- Private inbound isolation is effectively absent, and no app carries a health-check path for platform-level liveness detection.

Logic Apps Split Risk Profile

- The Logic App estate spans two hosting models with opposite risk profiles. The multi-tenant Consumption workflows are weak on identity but contained on exposure, gated only by keys carried in the trigger URL. The single-tenant Standard workflows are strong on identity but open on inbound network access, with public reachability near-universal and private isolation effectively absent.

App Service Plan Sprawl

- The plan count is unusually high for the workload it supports, with no SKU standardisation, and shared serverless tiers dominate. Production-facing workloads run on shared plans that carry no reserved compute and cannot be load-tested at sustained peak, several plans host no applications at all, and the entire estate sits on the retiring branches.

Storage

Storage accounts are the single largest source of security non-compliance in the estate. Transport-layer controls are strong, but authentication and network access controls are weak across the majority of accounts.

- Over two-thirds of storage accounts still allow shared-key authentication, a legacy access model that bypasses conditional access, MFA, and RBAC scoping. This is the highest-leverage remediation target in the storage domain.
- The majority of accounts allow public network access, and a material subset also permits anonymous blob access. A number of accounts breach all three controls simultaneously, representing the most critical exposure found in the assessment.
- HTTPS-only and TLS 1.2 are enforced almost universally, which is a strong transport-layer baseline.
- Access tiering is one-dimensional. Nearly all accounts sit on Hot tier with no lifecycle policies in place. Applying cool, cold, and archive tiers to long-lived audit and backup data would reduce ongoing storage costs.
- Spend is concentrated in the Dynamics 365 and VDC subscriptions, where auto-generated function app storage accounts inherit the same insecure default template at scale.

Compute

The virtual machine estate is concentrated in the legacy VDC subscriptions and is well protected at the disk level, but operational governance and backup posture need attention.

- Disk encryption is universal across the compute estate, which is the strongest single security signal found in the assessment.
- Public exposure is contained, with only a small number of VMs directly accessible from the internet.
- The majority of VMs have no network security group applied at the network interface level, reducing defence in depth on shared subnets.
- Over a quarter of the fleet runs legacy VM families (v2 and v3). Modernising to v5 would deliver meaningful price-performance improvements with no application changes in most cases.
- Backup coverage is inconsistent. A significant proportion of protected items are in a suspended or stopped state, and a number of recent backups report as unhealthy or failed. Production VMs without successful recent backups represent a compliance risk.
- Workload tier tagging is largely absent, making it difficult to apply differential patching, backup retention, or incident escalation policies based on criticality.

Recommendations

Security and Access Controls

- **Enforce Entra ID-Only SQL Authentication:** enforce Entra ID-only authentication on all SQL Servers and Managed Instances, eliminating the password-based attack surface entirely.
- **Authenticate the APIM Gateway:** enable authentication on all APIM products, closing the most direct path to data exfiltration through the integration gateway.
- **Enable Easy Auth on Function Apps:** enable Easy Auth (Entra ID) on all Function Apps not triggered exclusively by internal services, since unauthenticated Function Apps across the estate represent an open door.

Network Isolation

- **Privatise the Data Tier:** disable public network access on all production SQL Servers and the data tier, fronting them with Private Endpoints or VNet Service Endpoints.
- **Restrict Function App Exposure:** restrict Function App public access using Access Restrictions or Private Endpoints, applying IP allow-lists scoped to known callers at minimum.

Storage

- **Remediate Critically Exposed Storage Accounts:** disable public network access, anonymous blob access and shared-key authentication on the 54 accounts that breach all three controls at once, prioritising the Azure Data Lake Storage Gen2 (ADLS Gen2) accounts that hold adult social care and other sensitive data, and raise the four accounts still on TLS 1.0 to a minimum of TLS 1.2. Run this as an immediate remediation ahead of the estate-wide baseline policy, which prevents recurrence but does not fix the accounts already exposed.
- **Enforce a Storage Account Baseline:** enforce a Storage Account Baseline policy initiative at management-group root covering shared-key access, anonymous blob access, TLS minimum, HTTPS-only, and public network access.

Compute and Hosting

- **Right-Size Oversized VMs:** right-size oversized VMs through a monthly review using Azure Advisor.
- **Move Critical Apps to Dedicated Hosting:** move production-critical apps off shared Consumption plans onto dedicated, resilient hosting (PremiumV3, ElasticPremium, or ASEv3), as shared plans can be degraded by other tenants under load and cannot be deterministically load-tested.
- **Evaluate ASEv3 for Isolation:** evaluate ASEv3 for workloads requiring full network isolation, running on single-tenant, dedicated infrastructure with complete VNet integration to eliminate noisy-neighbour exposure.
- **Consolidate App Service Plans:** consolidate to fewer, well-engineered dedicated plans rather than provisioning per workload, simplifying VNet design, scaling policy, and cost attribution.
- **Rationalise Unused Plans:** rationalise unused App Service Plans with no hosted applications and introduce lifecycle controls to prevent recurrence.
- **Configure Health Check Paths:** configure health check paths on all production Function Apps to enable platform-level liveness detection.

Governance and Policy

- **Mandate CAF-Aligned Hosting:** mandate CAF-aligned deployment for all new App Service Plans, with no new workloads under legacy or root management groups.
- **Define Standard Hosting Patterns:** define standard hosting patterns documenting when ASEv3 is mandated over Premium, SKU selection per environment, and scaling and resilience expectations.
- **Restore VM Tagging Discipline:** restore tagging discipline on VMs by bulk-applying the VMTier tag to all untagged VMs and enforcing via policy on creation.
- **Consolidate Dynamics 365 Storage:** consolidate auto-generated Dynamics 365 storage accounts, standardising the ALM pipeline to apply the baseline policy template so the footprint does not regrow after remediation.

Cost and Financial Management (FinOps)

Current State Overview

CQC's Azure spend is high, growing, and largely untraceable to a service owner. Reported monthly spend varies depending on which platform-wide categories are included in a given view, but the underlying run rate is stable month to month. Non-production cost is not under control, and the estate cannot currently attribute spend to the services that drive it.

Major Cost Contributors

Storage as the Largest Category

- Storage, taking accounts and managed disks together, is the single largest cost category. The estate is large, manually created, and carries no lifecycle management and no tiering, with almost all data sitting in the hot tier.
- A backlog of older, non-current-generation accounts remains to be converted. Moving cold data to cool or archive tiers would yield meaningful annual savings.

Premium SKU Usage Across AIS Environments

- AIS runs premium tiers across every environment, including development and test: a premium App Service Plan per app, Premium API Management throughout, and Premium Redis Cache in every environment. A SQL Managed Instance also carries a virtual machine attached purely for file storage.
- This "premium-everywhere" pattern is a KPMG-era design decision that the workload does not justify, so non-production environments carry full production cost. The combined App Service Plan and Logic App spend in AIS is the dominant cost story in the tenant.

Defender as a Cost Driver

- Defender for Cloud is the largest single item inside the AIS subscription, driven by a Defender for API tier upgrade taken in response to the API Management scraping incident.
- The reactive control upgrade has hardened into a fixed cost, while the upstream root cause, the absence of rate-limiting on the Application Gateway and API Management, remains unaddressed.

Optimisation Challenges

No Showback, No Chargeback

- All Azure spend is booked as a single line under one cost centre. Tagging for cost centre, environment, owner and application is inconsistent in the legacy estate, and the new-world tags are not yet propagated.

- As a result, CQC cannot say what AIS, EDP or the Regulatory Platform each cost without manual extraction, and shared platform costs cannot be apportioned.

Partial Reservation Coverage

- Reservations cover Microsoft Fabric and selected VM families, and an annual audit removed unused reservations and renewed live ones. There is no reservation or savings-plan coverage for Cosmos DB, SQL PaaS or App Service, where Advisor flags available savings.
- The team is reluctant to commit to three-year reservations against workloads that may be re-architected during the rebuild. This is a reasonable position, but it leaves savings on the table in the interim.

FinOps Cadence with Finance

- There is no formal Technology Approval Board or FinOps forum. The monthly cost report is engineering-produced, reviewed with the Finance Business Partner and reconciled to forecast, but there is no joint optimisation cadence, no cost-focused service reviews, and no automated budget alerts.
- Cost is an after-the-fact reporting function rather than a decision input. The prevailing view in finance is that the current arrangement works and nothing is urgent, which itself reduces the pressure to optimise.

Potential Savings

Lever	Driver	Estimated Saving	Risk
Storage tiering and lifecycle on hot-only estate	Storage £25k/month, all hot	Mid-five-figure annual	● Medium
AIS rationalisation (APIM, ASP, Logic Apps, MuleSoft)	Premium-everywhere pattern	Major; specific £ pending model	● High
APIM Premium-to-Developer in non-prod (x4 envs)	KPMG-era “everything the same”	Several £k/month per environment	● Medium
V2 storage account conversion (backlog)	Advisor-flagged	Direct cost saving	● Low
Defender for API tuning post rate-limiting fix	Reactive SKU upgrade	Avoids re-occurrence	● Low

Cosmos / SQL PaaS / App Service Savings Plan	No coverage today	Azure Advisor flags ~£25k headline	● High
--	-------------------	---------------------------------------	--------

Recommendations

Tagging and Chargeback

- **Enforce the Tagging Taxonomy:** adopt and enforce the CAF tagging taxonomy as Azure Policy, mandating Owner and CostCenter tags at vending intake, with a deny on subscription creation where a CostCenter tag is missing.
- **Stand Up a Showback Model:** build a Power BI showback model fed by Cost Management data, with named budget owners per service line.

Reservations and Commitment

- **Commit Compute, Defer the Rest:** adopt an Azure Savings Plan for compute, and defer reservations on rebuild-affected services until target sizing is known.

Right-Sizing

- **Rationalise High-Cost Workloads:** consolidate AIS App Service Plans and API Management, tune the Defender for API plan after the rate-limiting fix, and convert the legacy storage account backlog. For storage, first establish the split between storage accounts and VM-attached managed disks, then tier the hot-only estate to cool and archive.
- **Right-Size Fabric and SQL:** validate Fabric capacity against actual peak utilisation and pause non-production capacities out of hours, and review SQL service tiers against measured utilisation rather than headline assumptions.
- **Modernise VMs and Apply Hybrid Benefit:** modernise VMs to the current generation and apply Azure Hybrid Benefit on eligible Windows Server and SQL Server licences, both of which reduce unit cost with no architectural change.
- **Use Dev/Test Subscriptions for Non-Production:** vend non-production workloads into Azure Dev/Test subscription types to pick up automatic rate reductions, since the estate currently vends everything as standard EA subscriptions.

Networking

- **Restructure the Networking Spend:** audit gateway SKUs against active throughput, consolidate regional gateways into Azure Virtual WAN where the HSCN connectivity allows, and review the API Management tier against actual throughput rather than defaulting to Premium.

FinOps Cadence

- **Establish a Monthly FinOps Review:** run a monthly FinOps review paired with the existing service-management cadence rather than as a parallel forum, bringing engineering, architecture and finance together. Minimum agenda: actual versus budget by management group, the largest month-on-month movements, and one optimisation commitment per workload owner.
- **Make Cost a Design Input:** integrate a cost gate into the Architecture Steering Group so spend is a design input rather than an after-the-fact report.
- **Automate Budgets and Anomaly Detection:** configure budgets and alerts at management-group and subscription level, and enable Cost Management anomaly detection on the top cost-driving services to catch unintended consumption.

Focus Area: AIS (Application Integration Services)

Objective

Discovery of AIS workloads

- Discovery all current and planned integration flows, covering source systems, consumers, data sensitivity, and pattern type.
- Assess the fitness of existing integrations - including MuleSoft-managed flows - against AIS target architecture and identify migration or decommission candidates.
- Define standards across authentication, error handling and retry behaviour.
- Ensure observability across all flows with end-to-end traceability, alerting, and audit capability proportionate to data sensitivity.

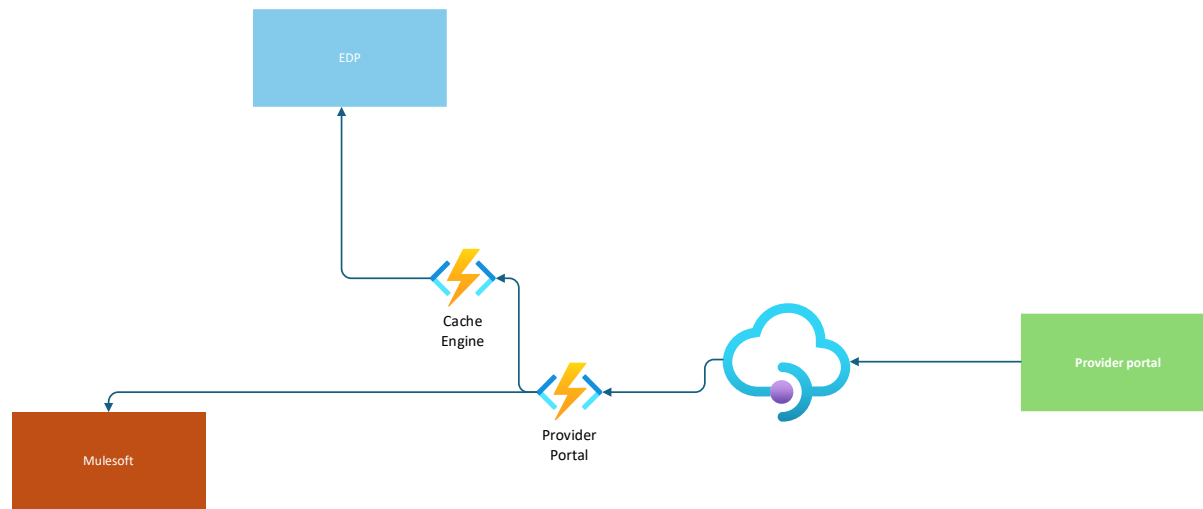
Solution Overview

The AIS is an Azure-based integration platform connecting internal and external systems across synchronous and asynchronous patterns. The synchronous layer is fronted by APIM, serving data from EDP and MuleSoft to Provider and Syndication consumers with layered caching to manage load. Asynchronous processing is built around Azure Service Bus, driving NHS ESR employee data ingestion and fanning out to Cygnum, Cornerstone, Dynamics FinOps, and EntraID; this pipeline carries GDPR-sensitive data with retention policies yet to be formalised. Several MuleSoft integrations - including Address Lookups and Cygnum registration - are candidates for migration into AIS, while the SOAD to Regulatory Platform flow is under review and may be descoped.

[illegible]

Provider portal

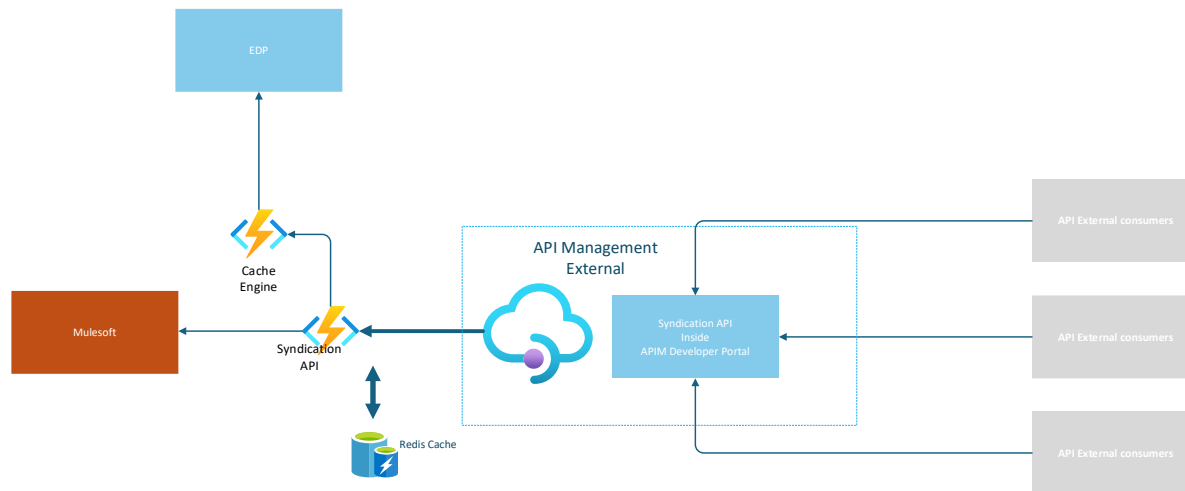
An internal CQC portal serving Registration and Assessment data from EDP and MuleSoft via APIM, with a Cache Engine reducing upstream load. The caching layer introduces a data consistency risk - locally cached data can drift from EDP, which should be the single source of truth, meaning data presented through the portal may not always reflect current state.



Syndication API

A public-facing API aggregating data from EDP and MuleSoft, exposed to external third-party consumers via APIM with subscription key access control and self-service onboarding through the APIM Developer Portal. At up to 5 million calls per day, a layered caching strategy - Cache Engine Function App backed by Redis - protects upstream systems from excessive load.

Two structural constraints shape ongoing operations: data is drawn from EDP and MuleSoft with no guarantee of consistency between them, with no single source of truth currently defined; and because consumers are external and independently managed, API changes must be non-breaking, requiring active version maintenance until consumers migrate at their own pace.

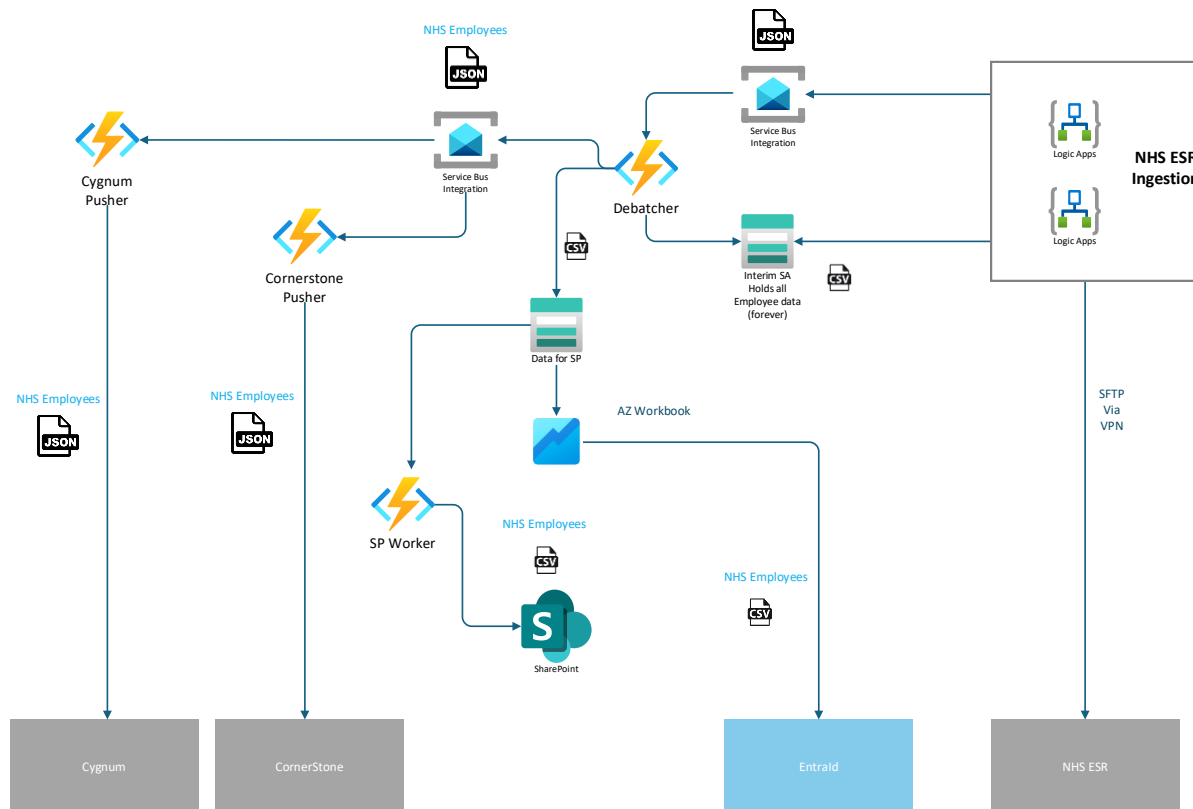


NHS ESR (Employees)

A scheduled, file-based pipeline ingesting employee data from NHS ESR via SFTP over VPN on a daily incremental and weekly full-refresh cadence. Inbound files land in a secured Blob Storage account before a Service Bus message triggers downstream processing.

Records are debatched into individual employee change events and fanned out to four downstream systems: Cygnum and Cornerstone receive upserts and deletions via HTTP sync APIs; EntraID and Dynamics FinOps are fed via staged CSV files picked up from Blob Storage.

All data in transit and at rest is GDPR-sensitive. An interim Storage Account currently retains a full copy of all employee data with no retention policy defined.



SOAD

A bidirectional, user-triggered integration between the SOAD .NET web application and Dynamics 365 CRM, pulling case data from CRM, applying SOAD-specific workflows, and pushing processed results back. The integration handles GDPR-sensitive mental health patient data throughout. Whether this workflow should be migrated entirely into Dynamics CRM - removing the AIS dependency and taking it out of scope - remains an open decision.



MuleSoft

MuleSoft is the existing integration platform planned for decommissioning. Integrations tied to systems also being retired - including Oracle OAC and i365 - are expected to be descope alongside it rather than migrated.

Two flows are candidates for migration into AIS: the Cygnum Registration API, which feeds registration data from CQC into Cygnum and is a natural extension of the existing NHS ESR pipeline; and the Address Lookup integration sourcing from Ordnance Survey, where the largely additive nature of address data presents an opportunity to introduce caching - potentially within EDP - to reduce upstream call volume and improve latency.

Observations - AIS

Current State Overview

AIS (Application Integration Services) is CQC's central integration platform, brokering traffic between the public-facing Registration Provider portal, the Syndication API, downstream regulatory systems and the Siebel CRM, as well as handling asynchronous processing of NHS ESR records. The estate inherits a uniform "premium-everywhere" sizing model, a divergent V1/V2 code line between Production and PreProd, hardcoded JWT tokens in APIM policies, and a "ClickOps" operating model on supposedly Terraformed infrastructure, compounded by reactive security spend, lingering legacy partner access in Production, and no reusable integration patterns. AIS is the single largest cost line in the tenant and the most operationally fragile workload, and it is the area most directly tied to DevSecOps maturity at CQC.

AIS Architecture

Two Code Bases, One Application

- Production runs the V1 code line while PreProd runs V2, so PreProd cannot act as a true staging gate, it does not match Production and therefore cannot validate changes against what is actually live.
- Every Production release is consequently all-or-nothing, with no equivalent environment in which to validate a change first.
- CAB is forced to act as the last line of defence on changes that should be routine, compensating manually for the absence of a representative pre-production gate.

Resource Group Structure

- The estate is concentrated into a single resource group, with resource-group boundaries that do not align to operational responsibilities.
- Infrastructure appears to be deployed through "ClickOps" rather than consistently through Infrastructure as Code, so environment state is not reliably reproducible and changes are not readily reviewable or auditable.
- Cost, RBAC and lifecycle decisions cannot be made cleanly at the resource-group level, and monitoring is difficult to attribute.

Click-Ops in Production

- AIS production subscriptions were singled out across multiple workshops as the worst case for standing privilege and "ClickOps".
- Developers and third parties hold permanent Contributor on Production.
- Manual changes routinely override Terraform, and the IaC baseline drifts within days of deployment.
- The estate cannot reach a baseline of code-driven change while developers hold permanent Contributor on Production. The drift is structural rather than incidental.

AIS Cost and Sizing

SKU Sizing Across Environments

- AIS runs Premium SKUs consistently across every environment, including development and test, so lower environments carry full production-grade cost on workloads that do not require it.
- App Service Plans and Logic Apps together form the dominant cost story in the tenant, with non-production environments such as PreProd carrying near-production cost despite being underused.
- Premium API Management runs in every environment, Premium Redis Cache runs in every AIS environment, and a SQL Managed Instance has a virtual machine attached purely for file storage, none of which generally require production-grade tiers to support functional or integration testing.
- The "premium-everywhere" pattern reflects an earlier decision to apply a single, uniform sizing model across the estate, accepted at the time as a simple and consistent approach. While holding certain hosting tiers steady across Prod, PreProd and Test can be justified for realistic testing, applying Premium uniformly across the entire estate is not appropriate and leaves lower environments carrying cost without a corresponding benefit.

Defender as a Reactive Cost

- Defender for Cloud is the largest single item inside the AIS subscription.
- The driver was a Defender for API SKU upgrade taken in response to an APIM scraping incident, in which a high volume of API calls were scraped through unprotected endpoints.
- The reactive control upgrade has hardened into a fixed cost, while the upstream root cause, the absence of rate-limiting on the Application Gateway and API Management, remains unaddressed.

AIS Security

JWT Tokens in Plaintext

- APIM policies contain hardcoded JWT tokens alongside embedded business logic.
- Hardcoded JWTs in policy are an exfiltration and rotation risk.
- Embedded business logic creates a fragile change surface that is difficult to test. APIM should be treated as a routing surface, not an application surface.

Legacy KPMG Access in Production

- Several Entra ID groups hold Contributor on AIS Production in addition to the deployment service principal, and one is believed to belong to KPMG and remains active.
- Networking-level exceptions for KPMG also persist on a core function-app NSG rule set supporting the caching layer for the Syndication API.
- This creates excess standing privilege, a cleanup risk if the legacy partner group is removed without dependency mapping, and a firewall exception that no current engineer can attribute.

AIS Monitoring and Observability

- Monitoring is inconsistent across Prod and Non-Prod environments, reflecting the same "Click-Ops" approach and the absence of any deliberate infrastructure-monitoring plan.
- The lack of business-data auditing creates risk around failed integrations, particularly where sensitive data is involved, because failures may pass undetected with no audit trail.

AIS Operational Maturity

Lack of Reusable Integration Patterns

- No defined onboarding process exists for AIS integrations, so every new design starts from scratch.
- CAB is overloaded with what should be standard integration changes, and design reviews are repeated for equivalent patterns.
- AIS pace is throttled by review overhead rather than engineering capacity.

Recommendations

Architecture and Operating Model

- **Engineer Environment Parity:** Close the V1/V2 code-base divergence as part of the AIS rebuild, so PreProd matches Production and can act as a true staging gate, allowing routine changes to be validated against what is actually live, rather than relying on CAB as the last line of defence.
- **Split the Monolithic Resource Group:** Break the single consolidated resource group into function-aligned resource groups (connectivity, hosting, solutions, troubleshooting), so cost, RBAC, lifecycle and monitoring can be attributed and governed at boundaries that map to operational responsibilities.
- **Publish the AIS Five Patterns Design Authority:** Publish the approved integration patterns and differentiate standard from non-standard changes, so CAB handles only the genuine exceptions while routine, pattern-conformant changes flow without manual gatekeeping (see Appendix: Integration Patterns).

Cost

- **Right-Size the AIS Estate:** Move away from the uniform "premium-everywhere" model toward sizing proportionate to each environment's actual need. Downgrade non-production APIM to Developer, drop Premium Redis Cache in non-production, and retire the SQL Managed Instance VM file-storage workaround. Retain production-aligned tiers only where they genuinely support representative testing.
- **Consolidate App Service Hosting onto a Unified ASEv3:** Consolidate App Service hosting onto a single App Service Environment v3 spanning Prod, PreProd and Test. This increases predictability, lower environments run on the same isolated, dedicated infrastructure as Production, removing multi-tenant variability so testing is genuinely representative, and strengthens security, since workloads run on single-tenant, network-isolated infrastructure deployed directly into the VNet. Co-locate plans on the shared ASEv3 and right-size worker pools per environment (smaller in Test, scaled up in Production) to keep non-production cost proportionate while preserving the predictability and security benefits.

Security

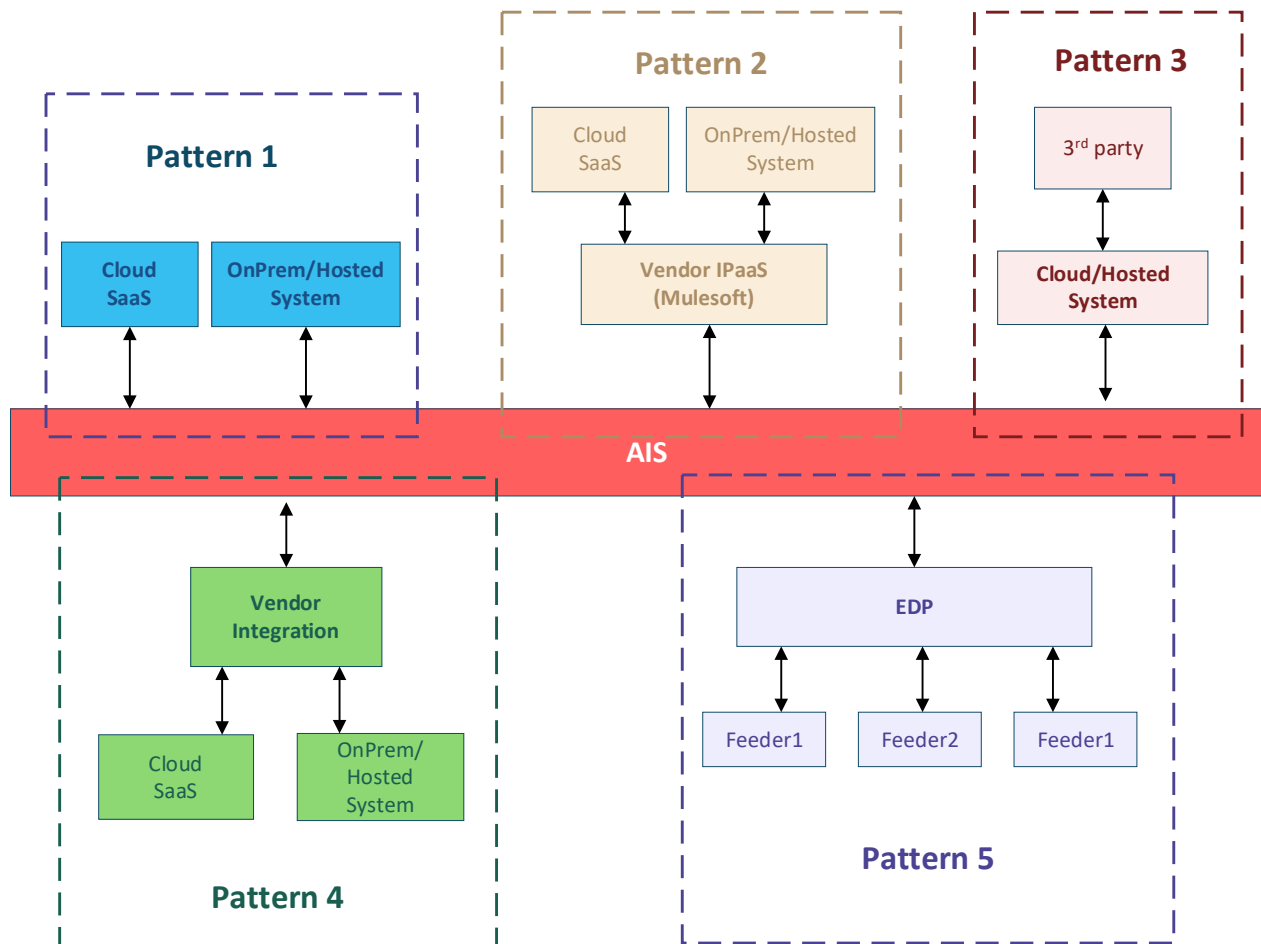
- **Close Out Legacy Partner Access:** Map dependencies on the legacy partner group, remove the legacy firewall exception, and convert standing AIS Contributor access to PIM-eligible, eliminating the permanent privilege held by developers and third parties on Production.

Operations

- **Bring AIS Under Code Control:** The estate already uses Terraform, so the gap is one of enforcement rather than adoption, manual portal changes routinely override the IaC baseline because the access and deployment model permits them. Remove standing Contributor access that enables direct portal changes (converting it to PIM-eligible, time-bound elevation), and route all changes through pipeline-driven Terraform deployments so that code becomes the only sanctioned path to changing AIS infrastructure. Reconcile the current drift by importing manually-created resources back into Terraform state, then hold the baseline by ensuring no one retains the standing privilege needed to bypass it.

Appendix: Integration Patterns Example

Analyse all business flows using core patterns before drafting technical solutions.



Pattern 1

All systems operate horizontally. Data produced by the system mastering a given entity is pushed AIS whenever an event or recurrence occurs. This provides full visibility of each data flow, with audit trails and notifications available for any infrastructure

outages or performance issues

Pattern 2

This pattern introduces an external integration layer, such as MuleSoft, between systems. Data is pre-processed within that layer, which can result in hidden transformations and undocumented business logic. Monitoring multiple platforms also increases troubleshooting complexity and may reduce visibility into infrastructure issues affecting the external integration platform.

Pattern 3

This pattern involves systems acting as master data sources for given entities, processing data from other third-party systems. Data is considered second-hand, with potential traceability issues in integration flows between hidden publishers and systems publishing to AIS. If traceability is deemed non-critical, this pattern can be simplified to the Pattern 1.

Pattern 4

In this collaboration pattern, external systems exchange data with a vendor integration solution hosted within the AIS landing zone. Services are securely hosted in the AIS landing zone. Communication between vendor integration services and external systems occurs via APIM, while communication can utilize the AIS landing zone and monitoring.

Pattern 5

The Master Data pattern (EDP) uses a Master Data Solution (MDS) as the single source of truth for key entities when no specific system has been designated as the master. Source systems integrate with the MDS to provide key data, which is then distributed to downstream systems through event-driven or scheduled processes. This pattern provides end-to-end visibility of data flows through audit trails, notifications, and infrastructure monitoring. However, it also increases the number of integrations and overall solution complexity, which can lead to higher implementation and operating costs. In return, it improves business data visibility and strengthens integration resilience, helping ensure accurate data remains available even if some source systems are temporarily unavailable.

Focus Area: Data and AI Platforms

Current State Overview

CQC's Data and AI platform landscape is operating in a **transitional and fragmented state**, characterised by a large and diverse Azure estate with inconsistent configuration patterns and a significant volume of legacy resources that have not yet been decommissioned. While strategic direction is emerging across the Enterprise Data Platform (EDP), Data Science, and AI, these capabilities are not yet fully implemented or operationalised at scale.

The estate reflects **parallel operating models**, with legacy and target-state platforms coexisting without clear convergence. This fragmentation is most evident across core services including EDP, data integration, governance tooling, and AI workloads, where differing architectural patterns, security postures, and operational approaches persist. The primary areas requiring focus are **governance, security, and operating model definition**, underpinned by the need to establish a cohesive, resilient platform foundation aligned to a clear architectural direction.

EDP represents the organisation's ambition to establish a **single source of truth** and the backbone for data-driven regulation. However, the current implementation remains split between a legacy Avanade-delivered "ARA" framework and an emerging Microsoft Fabric-led target architecture, resulting in duplication of capability and constrained modernisation. Supporting platform services are similarly fragmented: Microsoft Purview operates across multiple instances and portals; Azure Data Factory estates are large, costly, and inconsistently managed; and Azure Synapse workloads are siloed and difficult to support.

The Data Science and AI landscape demonstrates the same pattern. Multiple historical implementations of Azure Machine Learning Studio and Foundry remain active, each with differing configurations and levels of governance. Delivery remains largely experimental, with limited productionisation. A new interim platform and strategy have been defined, providing a **solid foundational direction (developing maturity)**, but these have not yet been consistently embedded across the estate.

Observations - Data Platform

EDP - The “ARA Lock-In”

The Avanade ARA framework introduces structural lock-in, with YAML-driven ADF pipeline generation, duplicated pipeline patterns, and reliance on a Node 4 support contract. Core platform changes require third-party engagement, limiting CQC’s ability to control the pace of modernisation. Debugging is complex and operational ownership is diluted.

Data Factory - Source Control, Parameterisation and Workload

The estate includes **21 ADF instances**, most without source control or CI/CD integration. Parameterisation is inconsistent, with duplicated linked services and datasets driven by hardcoded values. Naming conventions are inconsistent and some production instances are unused. Deployment is effectively uncontrolled, with recovery dependent on manual recreation, introducing **binary operational risk** in failure scenarios.

Synapse Analytics - Public Exposure and Legacy Workload

Synapse environments exhibit **incomplete security controls**, including enabled public network access, lack of data exfiltration protection, and no SQL auditing. Supportability is low, with limited knowledge retained within operational teams. Given current usage is limited (primarily Finance via Synapse Link), the workload represents a **candidate for rationalisation to Microsoft Fabric**.

Fabric - Monolithic Capacity and Non-Production Gaps

Fabric adoption is limited and capacity design is monolithic (F64, F128), with no pause/resume or scaling automation. This creates both **cost inefficiency and workload contention risk**, where competing workloads degrade performance and increase operational instability.

Fabric/Power BI - Dataflow Gen1 Dependency

Significant reliance exists on **Dataflow Gen1**, which is legacy and approaching deprecation. Transformation logic is duplicated across the data estate, increasing complexity and reducing maintainability. Business logic is distributed across multiple layers, complicating support and change management.

Inconsistent Encryption Posture

Encryption approaches vary significantly across the estate. Synapse uses Customer Managed Keys, while Databricks, Azure OpenAI, and AI Foundry use Microsoft-managed keys. This results in **weaker security controls for AI workloads**, which often handle sensitive training and prompt data.

Observations - Data Governance (Purview)

Two-Portal Purview Split

Purview operates across two instances, with production still on the legacy portal and no clear ownership or access to complete migration. This prevents **consistent catalogue management, classification, and governance enforcement** across environments.

GDPR Retention Vacuum

Sensitivity labelling is not operationalised, and GDPR-sensitive NHS ESR data is stored without defined retention policies. Data is held indefinitely in interim storage accounts, creating a **live compliance risk**, compounded by the absence of enforceable classification-driven controls.

Observations - AI and ML Operations

Data Science and AI Journey

The estate contains multiple legacy implementations of ML Studio and Foundry, none fully decommissioned. A new platform pattern is emerging, supported by a strategy that provides a **solid but developing foundation (Level 2–3 maturity)**. However, this requires evolution towards automation, standardisation, and product-led delivery.

Public Package, Private Risk

Data-science workloads rely on pulling public packages and container images from external sources, with vulnerability scanning performed via Defender for Cloud post-build. There is no formalised process or pipeline control, introducing **supply-chain risk** and placing responsibility at the individual practitioner level.

Lack of MLOps Maturity

There is currently **no formal MLOps capability**. Model deployment, monitoring, and retraining are largely manual, limiting supportability and auditability of production AI workloads. While strategy documents outline high-level concepts, they do not define a complete end-to-end MLOps framework.

Embedding AI and ML

The current approach is weighted towards **model development rather than operational consumption**. There is no clearly defined internal or external exposure strategy for AI services, increasing the risk of fragmented integration patterns, duplicated access logic, and inconsistent security controls.

Model endpoints are directly exposed (e.g. via Azure ML or Functions) without a managed gateway, removing key controls such as throttling, versioning, authentication abstraction, and policy enforcement. This creates **security, performance, and observability risks**, and constrains the ability to industrialise AI services at scale.

Additionally, there is no defined **Copilot or embedded AI experience layer**, creating a disconnect between platform capability and user adoption. Without integration into operational workflows and business processes, AI risks remaining a back-end capability with limited measurable impact.

EDP, Data and AI: Key Risks

- **Supplier lock-in on a critical platform component (ARA under Node 4)** limits CQC's ability to control EDP evolution, introduces dependency on third-party contracts for routine change, and constrains the pace of modernisation.
- **Fragmented platform architecture and parallel operating models** (legacy EDP vs Fabric, multiple ML/AI environments) create duplication of capability, inconsistent standards, and increased operational complexity.
- **Lack of controlled deployment and source management across Data Factory** introduces binary risk in production, with limited recoverability and high reliance on manual reconstruction in failure scenarios.
- **Security gaps within Synapse and broader estate** (public network exposure, no auditing, lack of data exfiltration controls) create material insider and external data exfiltration risk.
- **Encryption varies across data tiers.** Synapse runs with Customer Managed Keys, Databricks runs without them, and Azure OpenAI and AI Foundry run on Microsoft-managed keys.
- **Monolithic Fabric capacity design without scaling or automation** drives cost inefficiency and introduces performance contention, increasing the risk of workload failure and business disruption.
- **Reliance on deprecated and legacy components** (e.g. Dataflow Gen1) increases support risk, limits vendor supportability, and embeds duplicated transformation logic across the data estate.
- **Inconsistent encryption posture across platforms**, with AI workloads operating on weaker key models than core data services, creates a misalignment of controls where sensitive model and prompt data may be less protected.
- **Fragmented data governance capability** (Purview split across instances) prevents consistent catalogue management, classification, and enforcement of data controls across environments.
- **Active GDPR compliance exposure**, with ESR data retained indefinitely in interim storage and no enforceable retention or sensitivity labelling controls.
- **Public-package supply chain risk within data science workflows**, with reliance on external dependencies only validated post-build, and no enforced pipeline gates or platform-level control.
- **Absence of formal MLOps capability**, resulting in manual model deployment, monitoring, and retraining processes, limiting auditability, reproducibility, and operational support for production AI workloads.
- **No defined API-led exposure or productisation strategy for AI services**, increasing the likelihood of fragmented integration patterns, inconsistent access controls, and limited scalability of AI capabilities.
- **Direct exposure of model endpoints without a managed API layer**, removing critical enterprise controls (throttling, versioning, policy enforcement), increasing risks around security, performance, and observability.

- **Lack of an embedded AI consumption strategy**, including absence of Copilot-style integration, creating a disconnect between technical capability and user adoption, with risk of underutilisation and delayed value realisation.

Recommendations

Platform Architecture and Modernisation

- **Define and Enforce a Target-State Architecture:** converge on a simplified Fabric-led data platform and rationalise legacy technologies such as Synapse, duplicated ML environments, and Databricks where not required.
- **Reduce ARA Dependency:** pilot a Fabric-native orchestration and pipeline framework to return platform control and ownership to CQC.
- **Establish Environment Parity:** create environment parity and lifecycle consistency across data and AI platforms to support safe testing, validation and deployment.
- **Decommission Legacy Resources:** decommission legacy resources and workloads across all services as part of platform convergence.
- **Encryption Baseline:** move Databricks and OpenAI to Customer Managed Keys.

Data Engineering and Pipelines

- **Adopt Source Control and CI/CD:** connect all Azure Data Factory instances to Git-based source control and implement standard enterprise-aligned CI/CD pipelines.
- **Standardise Pipeline Patterns:** introduce standardised design and deployment patterns to eliminate ad hoc implementations.
- **Rationalise Duplication:** rationalise duplicated datasets, linked services and logging configurations to reduce complexity and operational overhead.
- **Optimise Integration Runtimes:** audit Integration Runtime usage, pausing unused SSIS-IR and using auto-resolve where appropriate.
- **Consolidate Data Factory Instances:** consolidate instances where multiple environments support the same logical workload, and align pipeline workloads to Fabric-native patterns where appropriate.
- **Retire Dataflow Gen1:** migrate off Dataflow Gen1 ahead of its deprecation and consolidate the duplicated transformation logic it carries.

Security and Encryption

- **Standardise Encryption:** implement Customer Managed Keys across Databricks, Azure OpenAI, AI Foundry and other applicable services.
- **Close Synapse Security Gaps:** enable data exfiltration protection and SQL auditing, and remove unnecessary public network access.
- **Adopt Private Networking:** transition services to private networking using Private Endpoints and DNS integration.
- **Control the Supply Chain:** introduce pipeline-enforced dependency controls so only approved, vetted artefacts are used, reducing reliance on post-build scanning.

AI and ML Operations (MLOps)

- **Establish a Formal MLOps Framework:** stand up CI/CD pipelines for model development and deployment, a centralised model registry with controlled environment promotion, and monitoring with drift detection and automated retraining.
- **Modernise ML Environments:** align ML Studio and Foundry environments to production-ready, MLOps-enabled designs.
- **Mandate MLOps for Production AI:** treat MLOps as a mandatory precondition for production and regulator-facing AI use cases, ensuring auditability and reliability.

AI Exposure, Integration and Productisation

- **Introduce an API-Led Architecture:** front AI services with a managed API layer (such as APIM) for standardised access, versioning, throttling and policy enforcement.
- **Define an AI Exposure Strategy:** define exposure for internal and external consumers, moving from direct endpoint integrations to governed service products.
- **Implement an AI Embedding Strategy:** drive adoption through Copilot-style integrations embedded in operational workflows and user-facing applications.

Platform-Specific Optimisation

- **Fabric:** implement automated scaling and pause/resume for large capacities (such as F64 and F128) to remove idle cost and workload contention.
- **Databricks:** review and consolidate workspaces, retaining them only where there is a clear requirement (high-volume processing, advanced data science, geospatial workloads), apply security best practices (CMK, diagnostics, private networking), and otherwise migrate workloads to Fabric and decommission.
- **Synapse Analytics:** where supporting Synapse Link or legacy workloads, modernise and align with the Fabric migration strategy, addressing security gaps as part of transition planning.
- **Machine Learning Studio and Microsoft Foundry:** modernise to align with MLOps and production deployment patterns, enforce private networking (Private Endpoints and DNS), and decommission redundant or legacy environments.

Consolidated Health Check Recommendations

The consolidated health check recommendations can be found in the supporting Excel file ***ACS_921 - CQC - Consolidated Health Check Recommendations.xlsx***

Technical Programme Leadership (Individual or group)

Why It Is Needed

Prioritisation is the dominant blocker identified in the Cloud Strategy analysis. CQC is under pressure from several directions at once: an inspection backlog, ageing systems, workforce strain, regulatory scrutiny, and the need to modernise while keeping services running. CQC is currently progressing all of these in parallel, which is producing fragmentation rather than progress.

Without a mechanism for deciding what comes first, tactical fixes accumulate without building towards the target state. Security remediation competes with platform migration. AIS cost reduction competes with the AIS rebuild. Decommissioning is deferred because no one owns the decision to stop.

A single point of authority is needed to sequence this work, hold the dependency map, and decide the order when workstreams compete.

The Technical Programme Leadership

The Technical Programme Leadership keeps the digital rebuild aligned with the direction set by the Cloud Centre of Excellence (CCoE) and the cloud strategy. It sits between the CCoE, which governs, and the delivery teams, which build, and is the point of accountability for scope, ownership and sequencing decisions across the rebuild. It brings together the technical leads for AIS, EDP, Reg Platform, the platform team, security and FinOps, and meets on a regular cadence so that prioritisation and sequencing decisions are made in one forum rather than workstream by workstream.

What the Technical Program Leadership owns

- **Prioritisation across the digital rebuild.** Decides the order of work across workstreams, balancing urgency, dependency, risk and capacity. When AIS, EDP, Reg Platform, security remediation and platform migration compete for the same people or change windows, the group makes the call.
- **Technical direction.** Sets architecture decisions, migration sequencing and pattern standards across AIS, EDP, Reg Platform and the platform estate.
- **Cross-cutting arbitration.** Where security, FinOps, governance and workload teams have competing demands, the group arbitrates and records the trade-off.
- **Transition governance.** Is accountable for retiring the legacy hierarchies, migrating workloads into the new CAF structure, and decommissioning orphaned resources against a published cadence.
- **Dependency management.** Maintains the cross-workstream dependency map, identifies where one team is blocked by another, and escalates accordingly.
- **CCoE alignment.** Keeps tactical delivery decisions consistent with the CCoE charter and escalates where they are not.
- **Stakeholder reporting.** Provides a single view of progress, risk, priorities and blockers across the digital rebuild, reported to the CCoE.

What the Group Does Not Own

- **Day-to-day platform operations.** These remain with the platform team.
- **Workload-level engineering.** The AIS, EDP and Reg Platform teams retain delivery responsibility for their domains.
- **Policy definition.** This remains with the cloud working group and the Technical Design Authority (TDA). The group enforces policy, it does not define it.

Roadmap

CQC's strategic direction is agreed and the target state is clear. The constraint is not ambition or capability. It is execution under pressure, where too many workstreams compete for the same people and the same change windows without an agreed sequence. This roadmap converts that parallel activity into a single sequenced and governed programme. It does not add new work. It changes how the work already underway is ordered, grouped, governed and delivered.

The roadmap is built from four connected parts that settle the questions decision-makers need answered before the rebuild can move at pace: who delivers the work, how it is grouped into deliverable units, when it happens, and what constrains the order.

- **Team and Organisation.** The capability, and the coordinating layer it needs. Delivery sits with the established Platform, Architecture, Security and workload teams, with the CCoE emerging as a function inside the Platform team. The change this roadmap adds is a Technical Programme Ownership group that sequences and prioritises across them.
- **Work packages.** The unit of delivery. The findings in this report resolve into 129 recommendations, and those recommendations group into sixteen owned, sequenced work packages. This is the layer that turns a backlog into a programme.
- **Phased delivery.** The timeline. Work is grouped into three phases by readiness rather than urgency alone.
- **Dependencies.** The order. A consolidated map of the conditions that decide what must come first, and the phase in which each is expected to resolve.

Every recommendation rolls up to exactly one work package, and every work package carries a single owner, a delivery phase and its cross-workstream dependencies. This is what allows each box on the plan on a page to be traced back to the evidence that justifies it. The plan presents the work packages across the three phases in a single view, the phases set the pace, and the dependency map fixes the order. Day-to-day delivery remains with the Platform, Security and workload teams throughout.

In short, the team and organisation changes add the coordinating layer, the work packages define the units, the phases set the pace, and the dependency map fixes the order.

From recommendations to delivery: the work package layer

The Cloud Health Check produced 129 recommendations, organised by domain. On their own they are an inventory of what to fix, not a plan for how to deliver it. Read as a flat list, they invite the same parallel, uncoordinated activity the programme is trying to leave behind.

The work packages close that gap. They group the 129 recommendations into sixteen named initiatives, each with a single accountable owner, a delivery phase and a defined set of dependencies. The grouping does not change the recommendations. It gives them a delivery shape. It also makes the plan auditable in both directions. Every recommendation belongs to exactly one package, and every package can be opened up to the recommendations beneath it.

The sixteen work packages are:

- **WP01 Programme and Operating Model Establishment** (Programme, Phase 1). Stand up the Technical Programme Ownership group and the Run and Service teams that sequence, arbitrate and own the rebuild.
- **WP02 Urgent Security Remediation** (Security and Platform, Phase 1). Close the eight high-priority exposure findings immediately: management ports, public IPs, key vaults, former partner access, PIM, the data tier and storage.
- **WP03 Landing Zone and CAF Consolidation** (Platform, Phase 1). Consolidate onto the new CAF hierarchy, freeze legacy placement, and standardise onboarding and subscription vending.
- **WP04 Governance Guardrails and Policy-as-Code** (Platform, Phase 1-2). Move policy from documentary to enforced, and publish the policy catalogue, NSG coverage and hosting standards.
- **WP05 Identity and Privileged Access Hardening** (Security, Phase 1-2). Eliminate standing privilege and click-ops, migrate flows to managed identities, and govern the guest lifecycle.
- **WP06 Threat Detection: Defender, Sentinel and B2C** (Security, Phase 2). Right-size Defender coverage, rationalise Sentinel analytics, and own the B2C migration ahead of the 2030 deprecation.
- **WP07 Network Topology and Connectivity** (Network, Phase 1-3). Hub-and-spoke in code, per-region firewalls, DR strategy, private DNS, and retirement of legacy connectivity.
- **WP08 External Exposure Reduction** (Network, Phase 1-2). DDoS Network Protection, public-IP rationalisation, and premium firewall inspection.
- **WP09 Secret and Key Management** (Platform, Phase 1-2). Vault-scoped RBAC, purge protection and diagnostics, and resolution of the shared cross-environment vault.
- **WP10 Observability and ITSM Uplift** (Operations, Phase 2). Consolidate monitoring, fix alert routing, move dashboards to code, and stand up the native ServiceNow connector.

- **WP11 Workload Security and Hosting Modernisation** (Integration, Phase 2). Authenticate SQL, APIM and Function Apps, restrict exposure, and rationalise compute and App Service hosting.
- **WP12 FinOps Operating Model and Cost Optimisation** (FinOps, Phase 1-2). Tagging and chargeback, reservations, right-sizing, and a monthly FinOps cadence with cost as a design input.
- **WP13 AIS Modernisation** (Integration, Phase 2-3). Environment parity, the Five Patterns design authority, resource-group split, and AIS under code control.
- **WP14 Data Governance and Compliance** (Data, Phase 1-2). Recover Purview, apply GDPR retention, embed classification, and standardise encryption across AI services.
- **WP15 Data and AI Platform Modernisation** (Data, Phase 2-3). Target-state architecture, pipeline rationalisation, MLOps, an AI exposure strategy, and legacy platform exit.
- **WP16 Legacy Workload Migration and Estate Transition** (Platform and Workload teams, Phase 3). Migrate or recreate the legacy spokes and workloads onto the new CAF hub, and retire the legacy hierarchies.

WP16 is the through-line the rest of the programme builds toward, and it is sequenced accordingly. It is described in full in the Phased Delivery section below.

Team and Organisation

The capability to deliver the rebuild already exists, spread across established teams. The change this roadmap needs is mostly organisational. It is a coordinating layer above the existing teams, not new delivery headcount.

The teams in place today:

- **Platform team.** Maintains the Azure tenant, landing zones, subscription vending, identity plumbing, networking and policy enforcement. The emerging Cloud Centre of Excellence (CCoE) is expected to sit within this team rather than as a separate body, setting standards, patterns and policy.
- **Architecture team.** Owns target-state design, pattern standards and migration design across the estate.
- **Security team.** Operates Sentinel, Defender for Cloud, PIM and incident response, jointly with NHS CSOC.
- **Project teams (workload teams).** The AIS, Data Platform and EDP, and Regulatory Platform teams deliver and modernise their own domains.

What is missing is not a delivery team. It is the layer that coordinates them. Each team is competent within its own domain, but no single body sequences across them, arbitrates when they compete for the same people or change windows, or owns the cross-workstream dependencies. The result is parallel delivery without coordination.

Two organisational changes close that gap:

- **The CCoE as a standards function within Platform.** The Cloud Centre of Excellence sits inside the Platform team rather than as a standalone body. It sets standards, patterns and policy, and governs exceptions, keeping governance close to the team that operates the platform.
- **A Technical Programme Ownership group.** This is the new element. Run as a steering group chaired by a single accountable owner, it brings together the Platform, Architecture, Security and workload leads. The group sequences and prioritises the rebuild, arbitrates trade-offs, and owns the dependency map. It is the named owner behind each work package, and its remit is set out in full in the Technical Programme Ownership chapter.

These changes do not stop the work already underway. They add the coordinating structure that turns parallel activity into a sequenced programme. With the CCoE established as a function within Platform, and the programme ownership group in place, the phased delivery below can proceed with clear accountability.

Phased Delivery

The work is grouped into three phases by readiness. Each phase sets out what continues, what changes, and which dependencies it clears. The dependency references are defined in full in the cross-workstream dependency map that follows this section.

Phase 1: Continue (foundations), Enable (organisation) and Stabilise (security)

Phase 1 lays the foundations, over roughly the first three months. The Platform team continues its landing zone, subscription vending and policy work, the programme and ownership structure is stood up, and the eight urgent security exposures are closed. Foundational work across governance, identity, networking, secrets, cost and data governance also begins. The migration runway is planned, but no legacy workloads move yet.

Phase 2: Consolidate and Standardise

Phase 2 makes delivery consistent, over roughly months three to nine. One-off fixes give way to repeatable, estate-wide standards, the workload teams adopt pre-approved patterns, and cost gains a named owner. Threat detection, observability and workload modernisation are delivered, and the AIS and data platform modernisation work begins. The first migration pilots run once the patterns are proven, while the legacy estate keeps running.

Phase 3: Transform, Migrate and Modernise

Phase 3 is where migration becomes the default, over roughly months nine to eighteen. With the foundations laid and the patterns proven, the bulk of the legacy estate is migrated onto the new CAF hub and the legacy hierarchies are retired behind it. The AIS and data platform modernisation packages complete, and the Platform team shifts from enablement to optimisation.

Work Packages

WP ID	Work Package	Owner	Phase	Total Recommendations	Dependencies cleared	Outcome / description
WP01	Programme & Operating Model Establishment	Programme	Phase 1	2		Stand up the Technical Programme Leadership group and the Run/Service teams that sequence, arbitrate and own the rebuild.
WP02	Urgent Security Remediation	Security / Platform	Phase 1	8	D5	Close the eight high-priority exposure findings immediately - management ports, public IPs, key vaults, partner access, PIM, data tier and storage.
WP03	Landing Zone & CAF Consolidation	Platform	Phase 1	5	D1, D2, D10, D17	Consolidate onto the new CAF hierarchy, freeze legacy placement, and standardise onboarding and subscription vending.
WP04	Governance Guardrails & Policy-as-Code	Platform	Phase 1–2	10		Move policy from documentary to enforced; publish the policy catalogue, NSG coverage and hosting standards.
WP05	Identity & Privileged Access Hardening	Security	Phase 2	9	D4, D16	Eliminate standing privilege and click-ops, migrate flows to managed identities, and govern the guest lifecycle.
WP06	Threat Detection - Defender,	Security	Phase 2	8		Right-size Defender coverage, rationalise Sentinel analytics, and own the B2C migration ahead of 2030 deprecation.

	Sentinel & B2C					
WP07	Network Topology & Connectivity	Network	Phase 1–3	10	D13, D14, D15	Hub-and-spoke in code, per-region firewalls, DR strategy, private DNS, and retirement of legacy connectivity.
WP08	External Exposure Reduction	Network	Phase 2	3		DDoS Network Protection, public-IP rationalisation, and premium firewall inspection.
WP09	Secret & Key Management	Platform	Phase 1–2	3		Vault-scoped RBAC, purge protection and diagnostics, and resolution of the shared cross-environment vault.
WP10	Observability & ITSM Uplift	Operations	Phase 2	10		Consolidate monitoring, fix alert routing, move dashboards to code, and stand up the native ServiceNow connector.
WP11	Workload Security & Hosting Modernisation	Integration	Phase 2	12		Authenticate SQL/APIM/Functions, restrict exposure, and rationalise compute and App Service hosting.
WP12	FinOps Operating Model & Cost Optimisation	FinOps	Phase 2	12	D3	Tagging and chargeback, reservations, right-sizing, and a monthly FinOps cadence with cost as a design input.
WP13	AIS Modernisation	Integration	Phase 2–3	6	D6, D9	Environment parity, the Five Patterns design authority, resource-group split, and AIS under code control.
WP14	Data Governance & Compliance	Data	Phase 1–2	10	D7, D8	Recover Purview, apply GDPR retention, embed classification, and standardise encryption across AI services.
WP15	Data & AI Platform Modernisation	Data	Phase 2–3	20	D11, D12	Target-state architecture, pipeline rationalisation, MLOps, AI exposure strategy, and legacy platform exit.
WP16	Legacy Workload Migration &	Platform / Workload teams	Phase 3	1	Clears D14	Migrate or recreate the legacy spokes and workloads onto the new CAF hub and retire the legacy hierarchies. Sequencing ramps: plan and prioritise the runway in Phase 1, run pilots as platform patterns prove out in Phase 2, then execute the bulk migration and

	Estate Transition					legacy retirement in Phase 3. Cannot begin in earnest until the landing zone (WP03), CAF hub (WP07), identity (WP05) and proven hosting patterns (WP11) are in place - which is why execution lands in Phase 3. Clears legacy hub retirement (D14). Note: under-represented in the 129 recommendations because a health check enumerates findings, not a migration backlog - that backlog is produced in the Design and Implement phase.
--	-------------------	--	--	--	--	--

Cross-Workstream Dependencies

The map below consolidates the dependencies referenced across the three phases into a single sequencing view. These are not sequential steps. Many run in parallel, but each row describes a condition where one activity cannot complete, or should not start, until another is resolved, and the phase in which it is expected to resolve. This is the programme ownership group's primary sequencing tool.

Each dependency has two ends, and both are named. The blocked work package, whose activity cannot proceed, and the clearing work package, whose work removes the constraint. Where both ends sit in the same package, the dependency is sequencing within a package. Where they sit in different packages, it is a cross-package dependency, and these are the links drawn between bars on the plan on a page. One dependency, D13, is triggered by an external event, the data centre closure, rather than by another package.

Of the seventeen dependencies, seven are cross-package, nine resolve within a single package, and one is externally triggered.

Cross-workstream dependency map

Ref	Blocked activity (package)	Depends on or trigger (package)	Type	Phase
D1	Tenant-wide policy enforcement (WP04)	Move the two bootstrap subscriptions into the Platform and Management group (WP03)	Cross-package	1
D2	Subscription migration into the new CAF hierarchy (WP03)	Freeze new placement under the legacy and old-CAF hierarchies (WP03)	Within package	1

D3	FinOps showback model (WP12)	Rename tag keys to the canonical names via Modify policy (WP03)	Cross-package	1
D4	Stale account cleanup (WP05)	Migrate user-identity flows to managed identities and complete access reviews (WP05)	Within package	1-2
D5	Removal of KPMG access from AIS Production (WP02)	Map dependencies on the legacy KPMG Entra ID group and NSG rules (WP02)	Within package	1
D6	Reduction of Defender for API cost (WP12)	Fix the APIM rate-limiting condition (WP13)	Cross-package	2
D7	Sensitivity label propagation into Fabric (WP15)	Recover Purview production access and migrate to the new portal (WP14)	Cross-package	1
D8	Interim SA retention compliance (WP14)	Apply retention policies to the Interim SA and ESR-bearing storage (WP14)	Within package	1
D9	AIS environment parity (WP13)	Close the V1 and V2 code-base divergence as part of the AIS rebuild (WP13)	Within package	2
D10	Retirement of the DevOps vending request route (WP03)	ServiceNow vending intake form live and tested (WP03)	Within package	1-2
D11	Synapse decommissioning (WP15)	Migrate the Finance workload from Synapse Link to Fabric Link (WP15)	Within package	2
D12	Removal of the Node 4 EDP support contract (WP15)	Pilot and prove a Fabric-native alternative to ARA (WP15)	Within package	2-3
D13	ExpressRoute circuit 1 decommissioning (WP07)	Data centre closure, a hard deadline at end of year (external event)	External trigger	1
D14	Legacy hub retirement (WP07)	All spokes and workloads migrated or recreated on the new CAF hub (WP16)	Cross-package	2-3

D15	Legacy DNS retirement (WP07)	Internal name resolution moved to Azure DNS (WP07)	Within package	2
D16	Click-Ops freeze in AIS (WP13)	Convert standing Contributor on AIS Production to PIM-eligible (WP05)	Cross-package	1
D17	Orphaned resource decommissioning at scale (WP03)	Agree and resource a published decommissioning cadence (WP01)	Cross-package	1-2

Ownership of the order, the trade-offs and the cross-team blockers sits with the Technical Programme Ownership group, led by a single accountable owner, whose remit is set out in the Technical Programme Ownership chapter. Day-to-day delivery remains with the Platform, Security and workload teams throughout.

Glossary of Terms

Term	Definition
AMBA	Azure Monitor Baseline Alerts. A Microsoft framework that defines a baseline set of alert rules per Azure service, deployable via IaC.
AMPLS	Azure Monitor Private Link Scope. A boundary object that allows Azure Monitor ingestion and query traffic to flow over private endpoints.
ARA	Avanade Data Platform Solution
ASE	App Service Environment. A single-tenant deployment of Azure App Service into a customer VNet.
AVS	Azure VMware Solution. A managed VMware Cloud Foundation environment running on Azure infrastructure.
B2C	Azure Active Directory B2C. A customer-facing identity service, scheduled for deprecation by Microsoft in 2030.
CAF	Cloud Adoption Framework. Microsoft's guidance for cloud adoption strategy, planning, readiness, governance and management.
CCoE	Cloud Centre of Excellence. The cross-functional body that defines standards, patterns and operating model for cloud.
CIS	Azure CIS (Center for Internet Security)
DSPT	Data Security and Protection Toolkit. The NHS-aligned annual assurance regime applicable to CQC.
FinOps	Cloud financial management practice. Combines technology, finance and business to drive cost accountability.

GovAssure	The Cabinet Office cyber assurance regime for UK government departments and arm's-length bodies.
IaC	Infrastructure as Code. The practice of provisioning and managing infrastructure via machine-readable definition files.
JIT	Just-In-Time. Time-bound, on-demand elevation of privileged access, granted only for the duration needed.
MLOps	Machine Learning Operations. The practice of deploying, monitoring and managing ML models in production.
NCSC CAF	National Cyber Security Centre Cyber Assessment Framework. The UK government baseline for cyber resilience.
NSG	Network Security Group. An Azure resource that filters network traffic between Azure resources in a VNet.
PIM	Privileged Identity Management. The Entra ID service that provides just-in-time elevation for privileged roles.
SoCC	Security Operations Centre Capability. NHS England-funded service that supports CQC's Sentinel operation.
TDA	Technical Design Authority. The internal review board that ratifies designs before implementation.
WAF	Web Application Firewall (or Well-Architected Framework, depending on context).

Contacts

For further information, please contact:

Jesmond Giordmaina

Technical Director

Hitachi Solutions

London office
110 Bishopsgate
23rd floor
London UK
EC2N 4AY

Email: jgiordmaina@hitachisolutions.com

Mobile: +7825 996 838

Office: +44 (0)204 526 8510

Change History

Date	Name	Version	Change Reference
9 th June 2026	Jesmond Giordmaina/Aaron Hughes	0.1	Initial Release for feedback. Data & AI section updates